

Risposte alle domande di sicurezza divise per capitolo

(1) Introduzione alla sicurezza

Come si affronta un'attacco?

Si affronta tramite:

Premption: fare in modo che l'attacco non venga portato a termine

Detection: accorgersi, individuare quando un dispositivo è sotto attacco

Recovery: ripristinare la situazione successiva all'accaduto

Cosa è una vulnerabilità?

Una vulnerabilità è un errore o bug volontario o involontario presente all'interno di un SW, che potrebbe causare problemi di sicurezza

Cosa è un exploit?

Un exploit è un programma che sfrutta una vulnerabilità per poter eseguire quello che vuole anche contro la volontà del proprietario (es aprire una shell). Gli exploit sono usati ma anche venduti

Cosa è un attacco?

Effettuare un attacco significa utilizzare un exploit solitamente per sfruttare una vulnerabilità presente nel sistema per ottenere qualcosa contro la volontà dell'utente

Cosa è una BotNet?

Una Botnet è una rete di computer infetti da malware e controllati da remoto da un attaccante chiamato botmaster. Vengono utilizzate per effettuare attacchi su larga scala

Cosa è il cryptojacking?

Fare cryptojacking significa utilizzare il pc di qualcuno infetto es.all'interno di una botnet e sfruttare la sua potenza di calcolo per effettuare mining di cryptovalute

(2) Sistema Sicuro

Quali sono le proprietà di un sistema sicuro?

Un sistema è detto sicuro se garantisce almeno 3 proprietà fondamentali tra le seguenti 6:

- Confidenzialità
- Integrità
- Disponibilità
- Accontabilità
- Autenticità
- Autorizzazione

Perchè un sistema sicuro non può essere garantito?

Perchè le seguenti non possono essere garantite:

- Confidenzialità: la parte di informazioni non pubblica del sistema è acceduta solo dalle persone autorizzate (un cellulare non può garantire questa proprietà, dato che ha molte app e può essere facilmente compromesso)
- Integrità: Il SW e i dati possono essere modificati solo da chi è autorizzato (non è possibile garantirlo a cause delle vulnerabilità presenti nel sistema potenzialmente non conosciute)
- Disponibilità: Il sistema deve sempre essere accessibile agli utenti (se sono sotto ad un'attacco DOS il sistema non è disponibile)

Quali sono alcune proprietà che dovrebbero avere le applicazioni di un sistema sicuro?

- Avere un meccanismo semplice e piccolo
- Utilizzare di default l'opzione più sicura
- Complete Mediation, quando viene effettuato l'accesso ad un'oggetto esso non può accedere direttamente ma deve farlo dopo essere stato autorizzato da chi ha i permessi per farlo
- Open Design, la parte di sicurezza e protezione di un sistema dovrebbe essere Open
- Least Privilege, allocare solo i permessi necessari e per la minor durata possibile
- Separation of privilege, ogni modulo si occupa di una singola parte del programma, è più facile da gestire e debuggare

Cosa sono i Principals e i Privilegi?

I Principals sono entità in un sistema informatico a cui vengono concesse autorizzazioni (utenti, entità comunicanti o processi di sistema). I privilegi (associati ai Principals) specificano le risorse e le loro autorizzazioni di accesso

Cosa è la Repudiation?

Repudiation o ripudio significa negare di aver compiuto un'azione. Se ho la non-repudiation vuol dire che un utente non può negare di aver compiuto un'azione (es. risulta dai log)

Quali sono le tre regole auree?

Le tre regole auree (così chiamate perchè iniziano tutte con Au, simbolo dell'oro) sono Authentication, Authorization, Auditing

Cos'è l'Autenticazione?

È la garanzia che un Principal, un dato o un software siano genuini rispetto alle aspettative derivanti dalle apparenze o dal contesto.

Come garantisco l'Autenticazione?

Entity authentication: il sistema è in grado di garantire che l'identità associata ad un principals è esattamente quella dichiarata es. Login con password

Data Origin Authentication: Sistema che garantisce che la fonte dei dati o del SW sia quella dichiarata. Implica l'integrità dei dati. Si può fare grazie a MAC o firme digitali. Nel caso MAC la firma è condivisa quindi non si ha non ripudio (un soggetto non può negare di aver fatto un'azione), nel caso di firma digitale sì: solo il mittente ha la chiave primaria e tutti possono verificare con chiave pubblica, e lui non può negarlo

Cos'è l'auditing?

È il processo di raccolta, registrazione e analisi degli eventi di un sistema (solitamente attraverso i log). Serve per poter rispondere alla domanda "Cosa è successo?"

Cos'è l'Accountability

Accountability è il principio secondo il quale ogni azione deve poter essere attribuita a un soggetto specifico. Per garantirla devo prima avere l'Auditing. Chi ha svolto un'azione non può negare di averlo fatto (repudiation) dato che è tutto registrato. I dati non devono poter essere cancellati (sono salvati ad esempio su memorie write once o sistemi esterni). Esistono sistemi che analizzano log e avvisano in caso di problemi

Cos'è l'autorizzazione?

Significa verificare le politiche di autorizzazione, verificando diritti e privilegi dell'utente e stabilendo che azioni può compiere nel sistema (es se pago un abbonamento ho più privilegi)

Qual'è la differenza tra Confidentiality e Privacy?

Confidentiality: (riservatezza) protezione delle informazioni per prevenire divulgazione non autorizzata

Privacy: riguarda le informazioni personali sensibili, la loro protezione e il controllo delle modalità di condivisione

Cosa sono le Security Policy?

Sono delle regole che stabiliscono per ogni sistema cosa, perchè e come è consentito. Un sistema viene messo in sicurezza grazie alle Privacy Policies. Un sistema non è sicuro se esse non sono rispettate

Cosa è una minaccia?

Una minaccia è qualsiasi combinazione di circostanze o entità che potrebbero danneggiare beni o causare violazioni di sicurezza

Di che tipo può essere una minaccia?

- Minacce Naturali/Ambientali: es. incendi alluvioni terremoti blackout
- Minacce Accidentali: es. cancellazione accidentale dei dati, configurazione errata di firewall, bug
- Minacce Intenzionali: es. attacchi interni di dipendenti, esterne attacchi malware, DOS etc.

Cos'è il CVE?

Il CVE (Common Vulnerability Exposures) è un identificatore pubblico standard per riferirsi ad una vulnerabilità di sicurezza conosciuta. Permette di riferirsi senza equivoci alla stessa falla e tracciarne patch ed aggiornamenti

(3) Rischio

Cosa è il rischio?

Il rischio è una perdita attesa dovuta ad eventi futuri dannosi, che potrebbero verificarsi in base a varie probabilità di rischio

Cosa significa approccio risk-based?

La protezione va adeguata a ciò che devo proteggere: più un oggetto vale più lo devo proteggere, altrimenti non ha senso (es. non metterò una bici in una cassaforte di una banca, costa più la protezione dell'oggetto in se)

Cos'è il Risk Assesment?

Il Risk Assesment è l'attività di valutazione del rischio, ovvero identificare i fattori di rischio e valutarli per stimare il rischio totale

Qual'è la formula per il calcolo del rischio?

$$R = T * V * C$$

Dove:

T = probabilità che una minaccia interessi il sistema

V = probabilità che esista una vulnerabilità nel sistema

C = valori dell'asset da proteggere, il costo al seguito di un'attacco con successo

Combinando T e V ottengo P ($T * V = P$) ovvero la probabilità che una minaccia compia un'azione che porta a sfruttare una vulnerabilità

Cosa sono l'ALE e la Risk Rating Matrix?

ALE: Annual Loss Expectancy, quantifica la perdita monetaria attesa per un'organizzazione di uno specifico rischio su un anno

Risk Rating Matrix: versione qualitativa e discreta della formula del rischio. È una tabella che rappresenta la probabilità di uno specifico rischio

Cosa significa Risk Management?

Combina le attività di stima e risposta del rischio, dove ho 4 possibilità:

- 1 Mitigazione del Rischio: abbasso il rischio di attacco
- 2 Trasferimento del Rischio: trasferisco il rischio a terzi
- 3 Accettare il Rischio: nella speranza sia meno costoso di 1 e 2
- 4 Eliminare il Rischio: mediante la dismissione del sistema

Nell'ambito di ISO27001 cosa vuol dire considerare la cybersecurity come un rischio?

ISO27001 è uno standard internazionale che definisce i requisiti per implementare, mantenere e migliorare un sistema di gestione della sicurezza delle informazioni. La cybersecurity è un rischio perché ci sono dati confidenziali e riservati che potrebbero essere rubati, o asset online che vanno protetti in base alla loro importanza

Cosa sono Adversary Modeling e Threat Modeling?

Adversary Modeling: processo del descrivere in modo sistematico chi può attaccare il sistema, con quali capacità, motivazioni e vincoli

Threat Modeling: processo del descrivere in modo sistematico il tipo di minacce che possono attaccare il sistema, gli attack vectors, le minacce etc.

Cosa è lo STRIDE? Quali sono le sue categorie?

È un modello di Thread modelling che classifica le minacce in 6 categorie. Applicando lo STRIDE si anticipano le minacce prima che accadano. Le categorie sono:

- Spoofing: impersonificazione di un'altra entità/persona (attacco all'autenticità)
- Tampering (manomissione): Alterazione non autorizzata di dati
- Ripudio: negare di aver svolto un'azione (si evita con log e accountability)
- Divulgazione di informazioni (Information disclosure): diffusione non autorizzata di dati
- Denial of service: attacchi che rendono inutilizzabile un sistema
- Escalation dei Privilegi: attacco che un utente ottiene privilegi per fare cose non autorizzate

Cos'è il Penetration Testing? Quanti e quali tipi ne esistono?

I test di penetrazione sono degli attacchi effettuati da hacker benevoli verso un sistema, per testarne la robustezza e livello di sicurezza. Ne esistono di tre tipi:

- Black-Box: l'hacker non conosce niente del sistema
- White-Box: testing più specifico dove gli hacker hanno origine ai sorgenti ed a vari script, permettendogli l'analisi del codice, facendo un'analisi mirata
- Grey-Box: Via di mezzo, l'hacker può avere accesso ad alcuni sistemi ma non ad altri

Per iniziare un penetration testing la prima cosa da fare è raccogliere informazioni sul target, così da capire che tipo di attacco effettuare

Cosa è una superficie di attacco? Quali sono le più comuni?

Le superfici di attacco sono i punti di un sistema esposti ad attacchi. L'obiettivo della cybersecurity è ridurre le superfici di attacco. Le più comuni sono:

- Network: porte aperte, API endpoints
- Hardware: fino a qualche anno fa sicuro, ora ci sono attacchi es rowhammer
- Software: Sistema Operativo e dati
- Human: Errore umano, il peggiore (es phishing, social engineering)

(4) Modelli di Accesso

Cosa è il Reference Monitor?

Il Reference Monitor legge le politiche (chi può fare cosa), verifica se un soggetto è autorizzato ad accedere da qualche parte e lo registra nei log. È un concetto astratto che racchiude tutti i meccanismi di sicurezza di un sistema, è formato

da più componenti. Si cerca di evitarlo durante gli attacchi tramite privilege escalation, diventando root

Cos'è la Controlled Invocation?

La Controlled Invocation è il principio per cui ogni accesso a una risorsa deve passare dal Reference Monitor. Il Reference Monitor intercetta ogni richiesta di accesso (system call), verifica la policy di sicurezza e decide se autorizzare o meno. È legato al principio di Complete Mediation: nessun accesso deve bypassare il controllo

Come funziona il “The Model” degli accessi?

- Un utente si autentica e chiede accesso ad una risorsa
- Il reference monitor legge le politiche e verifica se esso può accedervi
- Se si gli garantisce l'accesso, altrimenti lo respinge

Come si definiscono le fasi di Identificazione, Enrollment ed Autenticazione?

- Identificazione: stabilire l'identità dalle informazioni disponibili, senza che sia stata dichiarata un'identità esplicita
- Enrollment: fase di creazione dell'utente
- Autenticazione: processo di verifica nel quale si utilizzano prove a supporto per constatare l'identità dichiarata

Come funzionano le password? Dove sono salvate? Vantaggi e svantaggi

Le password sono un sistema di accesso che permette di accedere se una password combacia con un dato username. Esse sono salvate in un file, in Unix ad esempio:

`/etc/passwd`: contiene le utenze del sistema

`/etc/shadow`: contiene le password hashate (dato che l'utente root può accedere al file delle password)

Hanno il vantaggio di essere semplici, facili da imparare, gratis e veloci

Lo svantaggio è che l'utente le crea semplici per ricordarle, quindi sono facili da indovinare

Il sistema delle password è teoricamente perfetto, il problema è l'errore umano. È ancora oggi il sistema di accesso più diffuso al mondo

Quali sono alcune strategie per indovinare le password?

- Online/Offline Password Guessing: si tentano le password più popolari (online contro un server, offline in locale) si fanno molti tentativi magari avendo già alcuni user id validi

- Bruteforce Attack: Provare tutte le combinazioni possibili. Con l'hashing è quasi inutile
- Dictionary attack: avendo l'hash della password, utilizzando un dizionario (contenente tantissime parole comuni usate nelle pw, hashate) si effettua l'hash di tutte le parole finché non trovo quella che combacia col mio dizionario. Per evitarlo si usa il salt così da rendere inutile il dizionario
- Password capture: intercetto la password e la utilizzo
- Password interface bypass: supero i meccanismi di autenticazione
- Defeating Recovery Mechanism: trovo una vulnerabilità nel sistema di recupero password

Quali meccanismi alternativi alle password ci sono? Cosa è il multifactor authentication?

I processi di autenticazione possono essere di 4 categorie:

- what you know: una password che sai
- what you have: token digitale o hardware fisico
- what you are: impronte biometriche, tratto fisico distintivo
- where you are: localizzazione utente

Uso un Multifactor Authentication quando per autenticarmi uso almeno 2 di queste

Quali sono le controindicazioni del multifactor authentication?

Il multi-factor aumenta la sicurezza ma:

- Può ridurre l'usabilità
- Può essere aggirato con phishing avanzato
- Dipende dalla sicurezza del secondo fattore
- Non elimina completamente il rischio

Cosa sono le OTP

One Time Password, password temporanee inviate ad esempio via mail, forniscono un codice di accesso di durata limitata

Come funziona la Biometria?

La biometria è un sostituto delle password e permette di accedere ad un sistema usando i propri tratti fisici (o anche comportamentali in sperimentazioni moderne). Sono molto sicure ma a volte scomode e hanno comunque una loro insicurezza. Bisogna scegliere se avere più falsi positivi o falsi negativi nel riconoscimento

Come funziona l'OAuth?

- 1) l'utente richiede l'autorizzazione al Authorization server, fornendo l'ID del client e il secret per l'identificazione
- 2) l'Authorization server autentica il client e verifica che la richiesta è permessa
- 3) Il proprietario della risorsa interagisce con l'Authorization server per fornire l'accesso
- 4) L'Authorization server renderizza al client un codice di autorizzazione o un token di accesso (a seconda del tipo concesso)
- 5) Con il Token di accesso, il client richiede l'accesso alla risorsa al Resource server

Come funziona il SSO?

L'SSO (Single Sign On) è un sistema che consente di usare un'unica password per accedere a più sistemi della stessa organizzazione (es. Google). L'utente (client) si autentica ad un'entità che verifica l'identità, l'entità genera un token, lo invia all'utente e questo token verrà utilizzato da più applicazioni. (OAuth)

(5) Unix Access Control

Quali sono i modelli di Access Control più diffusi?

- D-AC (Discretionary Access Control): protocollo di accesso a discrezione del proprietario della risorsa. È implementato nei sistemi più diffusi (es. in linux su ACL)
- M-AC (Mandatory Access Control): Un amministratore della politica di sicurezza definisce, per ogni oggetto (risorsa), quali soggetti hanno quali permessi su di esso. Usato in Windows e SecureLinux. Un tipo di M-AC è il MLS (Multi Level Security) assegna ad ogni user (subjects) un livello di sicurezza (ES) corrispondente a una categoria: Top Secret, Secret, Confidential, Controlled Unclassified, Unclassified.

In quale caso utilizzo uno o l'altro?

Solitamente si utilizza MAC quando è richiesta della sicurezza (es. presenza di dati sensibili), nei pc personali il DAC è sempre presente e il MAC si attiva se c'è necessità di sicurezza aggiuntiva

Cosa è la ACM?

Access Control Matrix. È una tabella bidimensionale con righe che rappresentano i subjects (utenti, processi etc) e colonne che rappresentano gli objects (file, directory, risorse). È una rappresentazione della security policy. Tuttavia è molto grande, sparsa (ci sono molte celle vuote) ed è impraticabile memorizzarla

direttamente. Si tratta di un modello concettuale più che di una implementazione effettiva

Cosa è e come funziona la ACL?

Access Control List. Prendendo le celle non vuote della ACM si memorizzano delle coppie che rappresentano chi può accedere a quel file es.

Alice -> rw

Bob -> r

Root -> rwx

Questi valori sono salvati all'interno di ogni file quindi accedendo si è in grado di capire chi può accedere a cosa. Le ACL sono salvate negli inode di un file: ogni file in una directory è un puntatore inode. Un elemento della ACL è detto ACE (Access Control Entry)

La ACL estende il modello UGO, che contiene solo 3 categorie per User Group e Other: Read Write X execute. E ha poi i 3 bit sicuri di setuid. WINDOWS NON USA UGO (verificare)

Cosa è e come funziona la C-List?

Capability list. Funziona al contrario di ACL ovvero memorizza per ogni subject a quali file può accedere, es.

Alice:

file1 -> rw

file2 -> r

È un token che fornisce l'accesso ad una singola risorsa. La C-List è associata ai subjects e non agli oggetti

Differenze tra ACL e C-List?

ACL indica per ogni file chi ci accede, C-List per ogni utente a quali file può accedere. Il sistema ACL è centralizzato (Il processo chiede l'accesso -> viene controllato se può accedere -> Decide) mentre il sistema C-List è decentralizzato (non c'è nessuna lista, basta avere il token: se hai il token accedi)

Come funziona il controllo degli accessi in UNIX?

Gli account sono salvati in `/etc/passwd` e le password hashate in `/etc/shadow`. Dopo l'autenticazione il sistema crea un processo con l'User ID (UID): 16 bit che identificano univocamente l'utente nel sistema. Tutti i processi generati dall'utente avranno quell'UID

Chi è il Superuser e cosa può fare?

Il superuser è l'utente con $UID = 0$, ha tutti i poteri nel sistema e ha tutti i security check disattivati. Può effettuare ogni azione e impersonare qualsiasi utente. Non può decifrare le password degli altri utenti, ma può cambiarle

Come viene determinato l'UID per ogni utente?

L'UID viene determinato alla creazione dell'utente: root è 0, gli altri utenti sono da 1 in poi

Come vengono generati i processi in Linux?

In Linux i processi vengono generati principalmente tramite la syscall `fork()`, che crea un nuovo processo duplicando quello chiamante. Il figlio eredita memoria, file descriptor e UID, usando il meccanismo Copy-On-Write per efficienza. Successivamente il figlio di solito chiama `exec()`, che sostituisce il codice del processo con quello di un nuovo programma.

Che permessi hanno `/etc/passwd` ed `/etc/shadow`?

Il file `/etc/passwd` ha tipicamente permessi 644 ed è leggibile da tutti perché contiene informazioni pubbliche sugli utenti ma non le password. Le password sono salvate in `/etc/shadow`, che ha permessi 600 ed è leggibile solo da root. Le password sono memorizzate come hash con salt, utilizzando funzioni come SHA-512 o yescrypt, per proteggerle da attacchi come rainbow table o brute force offline.

Perché fare un bruteforce su shadow invece di cambiare password?

Non si cambia direttamente la password perché per modificare `/etc/shadow` servono privilegi di root o autenticazione legittima. Un attaccante che ottiene il file shadow può invece effettuare un attacco brute force offline senza generare log o limitazioni di tentativi. Per questo le password sono salvate con hash salati e funzioni lente, per rendere costoso il brute force.

Come funziona l'hashing di una password ed il salt? Quali sono gli algoritmi più usati?

Una password viene salvata hashata quindi non salvata in chiaro. Quando fai login inserisci la password, la password viene hashata e confrontata con quella salvata, se coincidono puoi fare l'accesso. Una buona funzione hash deve essere deterministica, non invertibile e veloce

Il salt è un valore casuale generato per ogni utente che viene aggiunto alla password quando viene hashata, così che ogni utente abbia hash diversi anche

con la stessa password, ed evita gli attacchi con rainbow table (salvo milioni di hash e li confronto)

Le funzioni hash più utilizzate sono sha2 e sha3, md5 lo era ma ora non è più sicura

Cos'è e come funziona l'UGO Permission Model?

L'UGO Permission Model è il modello di controllo accessi base di Unix. Ogni file ha permessi separati per User, Group e Others, e per ciascuna categoria si definiscono i diritti di lettura, scrittura ed esecuzione. I permessi sono memorizzati nell'inode e verificati dal kernel tramite l'EUID del processo. È un sistema semplice ma rigido: ci sono solo 3 categorie, e non possono assegnare privilegi diversi a membri dello stesso gruppo. Per questo esistono le ACL che estendono il modello UGO

Cos'è la Privilege Escalation?

È la funzionalità che permette ad un processo/utente di aumentare temporaneamente i suoi privilegi per eseguire un'attività specifica che richiede autorizzazioni più elevate

Cosa sono RUID ed EUID?

RUID (Real UID) identifica l'utente che ha avviato il processo

EUID (Effective UID) determina i privilegi effettivi che il processo ha

Cos'è il SETUID?

È un bit speciale nei permessi che fa sì che quando il file viene eseguito, il processo assuma l'UID del proprietario del file invece di quello di chi lo esegue. Permette quindi di effettuare operazioni che normalmente non potresti fare es. scrivere in file di root. Si rappresenta come s nei permessi. Una S maiuscola indica che ha setuid ma non è eseguibile, s invece ha setuid ed è eseguibile

Come si implementa?

Ogni processo linux ha tre UID

RUID: Real UID, UID dell'utente che lancia il processo

EUID: Effective UID, UID usato del kernel per controllo degli accessi

SUID: Saved UID, è una copia di EUID che serve per ripristinarli dopo averli abbassati

Nei processi normali $RUID = EUID = SUID$

Quando invece SETUID è attivo, allora RUID non cambia ma EUID diventa l'UID del proprietario del file

Il cambio di UID avviene durante `exec()` non durante `fork()`: quando creo una fork vengono copiati gli UID del processo padre, quando viene chiamato `exec()` allora `EUID = UID proprietario`

Se un programma con SETUID fa fork che UID ha il figlio?

Se un programma con SETUID attivo esegue una fork, il processo figlio eredita RUID, EUID e SUID del padre. Quindi, se il processo padre ha EUID elevato (ad esempio root), anche il figlio mantiene quell'EUID. La fork copia lo stato del processo; il cambio di UID avviene solo in fase di `exec` quando viene eseguito un file con il bit SetUID. L'unica cosa che cambia nel figlio è il PID, segnali e file locks

Come imposto SETUID tramite comandi?

Posso utilizzare `chmod`: un 4 inserito prima dei permessi indica SETUID ad esempio `chmod 4755 nomefile`

(6) Auditing e Log

Cosa sono Detection e Protection?

Detection: accorgersi di qualcosa non autorizzato in atto

Protection: Cercare di difendersi

Cosa sono i file di Log?

I file di log sono file che tengono traccia delle attività svolte nel sistema, qualsiasi cosa avvenga è scritta in essi (tranne le informazioni private). Sono composti da Entry contenenti informazioni relative ad uno specifico evento che si è verificato nel sistema o in rete.

I file di log vengono memorizzati ciclicamente, per evitare che si riempi la memoria di log. Il formato dei file di log non è standardizzato, ogni servizio sceglie il suo formato.

Dove vengono salvati?

Su Windows:

`/Windows/System32/winevt/Logs/`

Su Linux:

`/var/log/ /var/log/auth.log /var/log/syslog`

Cosa devono garantire i file di log?

confidenzialità (contengono dati sensibili)
integrità (non devono essere modificabili)
disponibilità (non devono perdersi)

Come si chiamano in Windows i file di log?

Si chiamano Event Logs e sono salvati in `/Windows/System32/winevt/Logs/`

Come si può evitare l'utente root cancelli i file di log?

Root può fare quasi tutto, quindi bisogna:

- Inviare i log a un server remoto (log centralizzati)
- Usare append-only file system
- Usare sistemi WORM (Write Once Read Many)
- Monitorare modifiche ai log
- Fare la separazione dei ruoli (least privilege)

Il punto chiave: log remoti e centralizzati

Quali sono le problematiche dei file di log?

- Possono essere molto voluminosi
- Sono difficili da analizzare manualmente
- Possono essere cancellati o modificati
- Se non sono monitorati in tempo reale diventano inutili
- Possono contenere dati sensibili
- Inoltre, se l'attaccante ottiene privilegi elevati può tentare di cancellarli per coprire le tracce

Chi fa l'analisi dei log?

L'analisi dei log può essere fatta manualmente da un sistemista, oppure in maniera automatica tramite IDS o SIEM

Come si accorge un sistemista di una privilege escalation?

Può notarlo tramite:

- Log di autenticazione
- Eventi di cambio UID
- Uso anomalo di comandi privilegiati (sudo)
- Creazione di nuovi utenti root
- Accessi fuori orario
- Modifica di file sensibili (/etc/shadow)

Come può essere fatta la detection dei log?

La detection dei log può essere fatta in tempo reale (es. utilizzando un IDS) oppure a posteriori, analizzando i log per capire cosa sia successo

Cosa è un IDS?

Un IDS è un Intrusion Detection System, controlla i file di log in tempo reale mentre vengono generati e riferisce eventuali anomalie

Cosa è un SIEM?

Un SIEM è un Security Information Event Managment. È un sistema che raccoglie e analizza informazioni in tempo reale, migliora la normalizzazione e analizza i file di log. La SIEM aggrega e normalizza i formati di file di Log (differenti tra loro) provenienti da applicazioni differenti. Un SIEM utilizza il Machine learning sui log passati, per riconoscere pattern di log pericolosi. Dopo aver rilevato un pattern pericoloso lo segnala al Security Analyst

(7) Exploitation e Software Security

Qual'è la differenza tra Hard link e Soft link?

Hard Link: Stesso Inode, Punta al contenuto, Non attraversa FS. Se cancello il file originale il contenuto resta finchè esiste un hard link

Soft Link: Inode Diverso, Punta al Percorso, Attraversa FS, Se cancello il file originale diventa un dangling link

Cos'è TOCTOU?

TOCTOU è una vulnerabilità che avviene quando c'è un intervallo di tempo tra il controllo di una condizione e l'uso effettivo della risorsa.

Nel caso del TOCTOU, la race condition è: La finestra temporale tra il controllo (Check) e l'uso (Use) di una risorsa. Esempio

```
if (access("/tmp/output.txt", W_OK) == 0) { int fd = open("/tmp/output.txt",  
O_WRONLY); write(fd, "ciao", 4); }
```

Nel tempo tra access e open, creo il file output.txt e lo linko a etc/shadow con `ls -sf /etc/shadow /tmp/output.txt`

Quando faccio la open, in realtà aprirò /etc/shadow e ci scriverò dentro con privilegi root

Cos'è una Race Condition?

Una Race condition si verifica quando due o più thread o processi simultanei accedono a una risorsa condivisa in un modo che produce involontariamente risultati diversi a seconda della sequenza o della tempistica dei processi o dei thread

Quale proprietà uso per evitare le Race Condition o TOCTOU?

La complete mediation è una proprietà secondo la quale l'accesso ad ogni oggetto del sistema va controllato ogni volta, non solo una o dopo un login. Ogni volta che un processo viene letto o controllato o accedo ad una risorsa quell'accesso va verificato. Se applico la complete mediation neutralizzo i problemi di race condition e TOCTOU, perchè anche se i permessi cambiano durante l'esecuzione comunque viene effettuato il controllo

Cos'è lo Stack? Cosa punta al suo ultimo elemento?

È una zona di memoria LIFO, tutte le CPU hanno le istruzioni per accedervi (PUSH e POP). Ogni processo ha il suo stack gestito dal compilatore. Il registro RSP contiene l'indirizzo all'ultimo elemento caricato nello stack. Lo stack cresce verso indirizzi più bassi e contiene variabili locali, parametri, indirizzo di ritorno. Il registro RSP contiene l'indirizzo all'ultimo elemento caricato nello stack

Cos'è e come è fatto lo Stack Frame? Che registri ha?

Quando avviene una chiama di funzione nel programma, uno Stack Frame viene allocato, contenente tutte le informazioni richieste per gestire l'esecuzione della funzione. Lo stack frame contiene

RSP -> punta alla cima dello stack RBP -> base dello stack frame corrente RIP
-> instruction pointer

Ogni funzione crea uno stack frame:

Salva il vecchio RBP (per tornare indietro alla funzione chiamante dopo la chiamata), i parametri passati dalla funzione chiamante, le variabili locali della funzione chiamata

Cosa sono CALL e RET? Cosa differenzia CALL da JUMP?

Sono delle chiamate di funzione che:

CALL: Salva l'indirizzo di ritorno sullo stack. Fa un salto incondizionato alla prima istruzione della procedura

RET: Prende l'indirizzo dalla cima dello stack e salta a quell'indirizzo (prende il valore di RSP e lo mette nel PC)

La differenza tra CALL e JUMP è che dopo CALL il controllo viene ritornato alla procedura alla sua terminazione usando ret, invece JUMP non garantisce di tornare indietro al chiamante della funzione

Come funziona la tecnica di Smashing The Stack?

In molte implementazioni di C è possibile corrompere l'esecuzione dello stack scrivendo oltre la fine di un array. Questo può causare la modifica dell'indirizzo di ritorno per saltare ad un indirizzo "random": può produrre bug e se utilizzato con intelligenza può portare ad eseguire del codice malevolo (Buffer Overflow):

Si riempie il buffer

Si sovrascrive il return address

Si fa puntare a codice controllato

Per poterlo fare però è necessario individuare l'indirizzo sullo stack del codice malevolo e del return address per poter eseguire il codice malevolo inserito. Intel utilizza little endian quindi interpreta i bit al contrario

Come funziona un Buffer Overflow?

Il Buffer overflow attack punta a cambiare l'indirizzo contenuto nel PC/IP per eseguire codice malevolo. L'obiettivo dell'exploit è prendere il controllo dell'IP (Instruction Pointer) di un processo per sfruttare bug di sicurezza presente nell'eseguibile. Avviene in 2 fasi:

1 Viene sovrascritto un puntatore di istruzione protetto

2 Il programma esegue un'istruzione legittima che trasferisce il controllo all'indirizzo fornito dall'attaccante

Se il buffer è nello stack posso sovrascrivere le variabili locali, l'RBP e il RIP

Quali sono le più comuni contromisure ai Buffer Overflow?

Le più comuni sono: - ASLR

- Stack Canary

- DEP

- NX

In generale la randomizzazione serve perchè in questo modo l'attaccante può sovrascrivere il return adress, ma non sa dove far saltare il programma quindi è inutile

Come funziona l'ASLR? Quali parti di memoria può randomizzare?

L'ASLR (Address Space Layout Randomization) randomizza stack heap librerie e base address rendendo gli indirizzi imprevedibili (tranne la sezione .text, per randomizzare anche quella serve PIE, Position Independent Executable). In sistemi a 32 bit è ancora possibile fare attacchi perchè ci sono poche possibilità randomiche, su 64 è quasi impossibile

Come funziona lo Stack Canary?

Viene anche chiamato Stack Guard (il nome canary fa riferimento alle vecchie mine dove mandavano un canarino per verificare la presenza di gas tossici). È posizionato tra lo stack frame della funzione ed il RA. A runtime si controlla se la guardia è stata modificata e in caso si termina. Viene inserito un valore segreto prima del return adress. Se esso viene modificato avviene il crash del programma. Viene inserito dal compilatore.

Fondamentalmente è un "rilevatore" di overflow

Cosa è l'NX?

No Execute, è un bit HW che marca della memoria come non eseguibile. Stack e heap non sono eseguibili. È stata bypassata dopo poco tempo perchè hanno scoperto che le funzioni di libreria del c hanno al loro interno dello shellcode

Cosa è la DEP?

La DEP (Data Execution Prevention) è una protezione a livello di SO + HW che marca alcune pagine come non eseguibili, in particolare: stack, heap, memory pool, buffer dinamici vengono trattati come dati non codice

Che tecnica posso usare per aggirare l'NX?

Invece di eseguire uno shellcode, si sovrascrive il RIP con indirizzo di funzione già esistente (es system()). Si usa del codice già presente in memoria, quindi non inietta codice ma riusa quello esistente. Questo metodo si chiama Return-to-Libc

Cos'è un Nop Sled?

Si tratta della tecnica del riempire prima dell'esecuzione di un codice con istruzioni NOP (0x90) che fanno "slittare" l'esecuzione del codice alla prima istruzione non NOP trovata. Questo può permettere di uscire da aree protette dall'esecuzione per esempio

Che conoscenze devo avere oggi per fare un Overflow?

Devo essere a conoscenza dell'indirizzo dello stack, conoscere come è fatto il canary (così da poterlo riscrivere). Invece di iniettare codice è più efficiente concatenare pezzi di codice già esistenti chiamati Gadgets. Questa tecnica si chiama ROP (Return Oriented Programming): non eseguo shellcode, eseguo codice già presente con un determinato ordine

Cos'è un Integer Overflow? Come lo si evita?

Un Integer Overflow si verifica quando il risultato di un'operazione aritmetica non è rappresentabile nel tipo di dato usato. Un overflow può trasformare un numero grande in uno piccolo: il programma crede che sia sicuro ma in realtà scrive fuori dai limiti, es.:

```
unsigned int x = 4294967295;
x = x + 1; // overflow, torna a 0
```

Può causare:

- Valori errati
- Bypass di controlli
- Allocazioni Sbagliate
- Buffer Overflow

Può essere evitato:

- Usando tipi coerenti (non mischiare unsigned e signed int)
- Controllando prima le operazioni
- Utilizzando funzioni safe
- Utilizzando Sanitizers

(8) Crittografia

Cosa garantisce la Crittografia? A cosa serve?

Serve a proteggere i dati contro accessi non autorizzati. Essa garantisce:

- Confidenzialità
- Integrità
- Autenticazione
- Non repudiabilità

Non garantisce la disponibilità

Quali problemi risolve? Cosa permette?

Risolve problemi come:

- Intercettazione (attaccante passivo, osservo ma non modifico i dati)
- Modifica dei dati (attaccante attivo, interagisco e modifico il contenuto)
- Impersonificazione

Permette di comunicare su un canale sicuro

Quali nuovi problemi introduce?

La crittografia con se porta problemi come:

- Gestione delle chiavi
- Distribuzione delle chiavi
- Complessità di implementazione
- Possibile falsa percezione di sicurezza

Gli algoritmi di crittazione sono noti? Qual'è l'inverso di ciò?

Si, solitamente gli algoritmi utilizzati sono noti, non è infatti l'algoritmo a garantire la sicurezza ma la chiave che viene usata con esso a farlo. L'inverso di ciò è detto Security By Obscurity, ovvero nascondere un algoritmo al pubblico per garantire maggior sicurezza (con il paradosso che potrei averne di meno, perchè se viene bucato solo io ne conosco il codice ed è più difficile trovare

una soluzione, rispetto ad un algoritmo pubblico che tutti conoscono e possono contribuire a migliorare)

Quali sono i due tipi di crittografia?

La crittografia simmetrica, ovvero con chiave pubblica ($k = k'$, le due chiavi sono uguali) e la crittografia asimmetrica, con chiave privata ($k \neq k'$, le due chiavi sono diverse)

Come funziona la Crittografia Simmetrica? Quali metodi di criptazione usa?

La crittografia simmetrica fa in modo che sia Encryption che Decryption usino la stessa key

Encryption: Messaggio $\rightarrow$ (K) $\rightarrow$ Criptato

Decryption: Criptato $\rightarrow$ (K) $\rightarrow$ Messaggio

Ci sono due metodi di criptazione utilizzati:

- Stream Cipher
- Block Cipher

Come funziona lo Stream Cipher? Quali sono alcuni esempi?

Lo Stream Cipher è utilizzato per cifrare sequenze di bit, consiste nell'applicare al messaggio lo xor con la key che deve essere di lunghezza pari al Plaintext. È stato matematicamente dimostrato che non si può decifrare in modo non consentito, per questo lo stream cipher si basa sulla Computational Security: sicurezza data dal fatto che per "rompere" quella sicurezza data dalla cifratura ci si impiega troppo tempo (oltre migliaia di anni)

Lo stream cipher più diffuso è probabilmente ChaCha20

Come funziona il Block Cipher? Quali sono alcuni esempi?

Il Block Cipher divide il messaggio in blocchi di uguale dimensione e cifra ogni blocco singolarmente, usando una chiave di lunghezza inferiore al messaggio m . Se l'ultimo blocco di dati non ha abbastanza bit viene riempito con bit di padding: un bit a 1 e poi bit di padding 0

Uno dei più usati era il DES (Data Encryption Standard): cifra blocchi di 64 bit ed ha chiave di 56 bit. Può essere tuttavia rotto in poche ore, quindi è stato sostituito con il Triple DES: utilizza tre chiavi da 56 bit, concatenando tre volte la cifratura DES con tre chiavi differenti.

Oggi viene utilizzato AES (Advanced Encryption Standard) come sostituto al Triple DES. Ci sono molte modalità per cifrare i blocchi come l'ECB (Electronic

Code Block, data una chiave k blocchi identici sono cifrati in egual modo) e il CBC (Cipher Block Chaining, a blocchi uguale corrisponde cipher text differente)

Quali sono i vantaggi e gli svantaggi della Crittografia Asimmetrica?

Vantaggi:

- Molto efficiente per tempo di esecuzione e dimensione
- La lunghezza della chiave è molto piccola

Svantaggi:

- La gestione delle chiavi è complessa e va condivisa a tutti i peer
- È un problema la condivisione sicura della chiave, è necessario un meccanismo di fiducia
- È più lenta della simmetrica (circa 2 volte)

Come funziona la Crittografia Asimmetrica? Cosa è la Hybrid Encryption?

La crittografia asimmetrica utilizza due chiavi, una pubblica ed una privata. La Encryption si effettua con la chiave pubblica e la Decryption con la chiave privata. Le due chiavi vengono generate insieme da un algoritmo e solo quella pubblica viene condivisa.

Dato che la cifratura simmetrica è molto più veloce si utilizza solitamente la Hybrid Encryption, ovvero si usano dei metodi a chiave asimmetrica per condividere la chiave simmetrica, e poi si usa quella

Come funziona RSA? Su quale problema matematico si basa?

RSA è un algoritmo di crittografia asimmetrica che si basa sulla difficoltà della fattorizzazione di grandi numeri primi. Vengono scelti due grandi numeri primi x e y . Viene calcolato il messaggio $m = x * y$, ed m diventa parte della chiave pubblica. Chi vede m non riesce a ricavare x ed y in tempi realistici, ma senza x ed y non può calcolare la chiave privata

Come funzionano le Firme Digitali? Cosa garantiscono?

La firma digitale è ottenuta usando un algoritmo a chiave pubblica associata univocamente ad una privata e permette di verificare che il messaggio sia stato generato dal proprietario della chiave privata

Si cifra un messaggio con la chiave privata e lo si invia assieme al messaggio come “sigillo digitale”, in modo da garantire autenticità del mittente. È un'operazione alternativa alla cifratura, utilizzando la chiave privata chiunque riceva la chiave pubblica può decifrarla per avere l'autenticità del mittente. Garantisce:

- Integrità: garanzia che il contenuto ricevuto è lo stesso firmato originariamente
- Autenticità: garanzia dell'identità di chi ha firmato il messaggio
- Non Ripudio: garanzia che un utente non può negare di aver mandato un messaggio se questo ha la sua firma. Deriva dal fatto che la verifica della firma non richieda la chiave privata del firmatario: i verificatori usano la chiave pubblica del firmatario

Le firme digitali sono usate insieme alle funzioni HASH per motivi prestazionali. Un'esempio di firma digitale è l'RSA

Come funzionano le Funzioni Hash? Che proprietà hanno?

Una funzione Hash è una funzione che prende in input una qualsiasi stringa binaria e produce un output di dimensione fissata chiamato “valore hash”. Le operazioni di hash sono molto veloci ed efficienti. In una buona funzione di hash cambiare anche solo un bit di input cambia almeno il 50% dei bit del risultato. Le funzioni hash godono di alcune proprietà:

- One Way property: per tutti i valori possibili hash, deve essere impossibile computazionalmente trovare un messaggio dato l'hash
- Second-preimage resistance: dato un valore di hash X dovrebbe essere impossibile trovare un'altro valore Y che produca lo stesso output
- Collision resistance: dovrebbe essere impossibile trovare una coppia di input distinti I1 ed I2 tali che il loro hash sia uguale. Quando due input distinti hanno lo stesso output ho una collisione

Le funzioni di hash più comuni sono sha2 e sha3, mentre md5 è deprecata

Come avviene la Firma Digitale tramite Hash?

La firma digitale avviene prima calcolando l'Hash del messaggio e successivamente si applica la chiave privata all'hash (di fatto firmando l'hash). La firma digitale avviene quindi cifrando l'hash con la chiave privata

Cosa è il MAC? Cosa garantisce?

Il MAC (Message Authentication Code) viene inviato per permettere di garantire l'integrità di un messaggio e l'autenticità del mittente (Data Origin Authentica-

tion). L'algoritmo che compone il MAC (MAC function) è una speciale funzione hash che prende in input una chiave segreta (secret key) e il messaggio. Richiede che la chiave sia condivisa a tutte le parti che devono comporre e verificare il MAC.

Inviando il messaggio e il MAC, il ricevente calcola il MAC del messaggio ricevuto in chiaro e se il MAC differisce c'è stata una manomissione o un errore di trasmissione. Il MAC quindi garantisce:

- Integrità
- Autenticità

Ma non garantisce il non ripudio (perché la chiave è condivisa a più utenti)

Come è implementato a livello Hardware il MAC?

I sistemi x86 hanno 4 ring (0-3):

Ring 0 -> Kernel (massimi privilegi)

Ring 3 -> User mode (applicazioni)

Serve per separare: - codice privilegiato (OS)

- codice non privilegiato (utente)

Il passaggio tra ring avviene tramite interrupt o system call.

Cosa è una SystemCall? Come Avviene un Interrupt Hardware?

Una System Call è un meccanismo con cui posso chiedere al Kernel di fare qualcosa es open() e write(). Il controllo accessi avviene a livello di system call

Un interrupt è un segnale inviato dall'hardware alla CPU

- Un dispositivo (es. tastiera) genera un interrupt
- La CPU interrompe il processo corrente
- Passa in modalità kernel (Ring 0)
- Esegue l'Interrupt Service Routine (ISR)
- Torna al processo precedente

Gli interrupt sono uno dei meccanismi che permettono il passaggio da user mode a kernel mode in modo controllato

Cosa sono CPL e DPL?

Il CPL è il privilegio corrente del processo, mentre il DPL è il privilegio richiesto da una risorsa. L'hardware permette l'accesso solo se $CPL \leq DPL$, garantendo che il codice utente non possa eseguire direttamente codice kernel senza una transizione controllata (syscall/interrupt)

Cos'è l'HMAC?

L'HMAC (Has-based Message Authentication Code) è un MAC costruito usando una funzione hash (es SHA) che usa una chiave segreta ed una funzione di hash

Cosa sono i certificati? Cosa è la CA?

Un certificato è una struttura dati che associa ad un subject una chiave pubblica. È firmato da un'entità esterna, la CA (Certificate Authority), un'entità fidata che fornisce i certificati. Per sua natura un certificato non può essere compromesso

Ogni certificato nei suoi campi ha anche una data di scadenza, anche se può essere terminato prima se viene persa o compromessa la chiave privata e si fa richiesta: tuttavia dalla richiesta alla revoca possono passare anche circa 2 ore ed in quel periodo potrebbero essere effettuati attacchi

L'integrità delle chiavi pubbliche è un problema perché non è possibile risalire al proprietario data la chiave pubblica

Cosa è la PKI?

La PKI (Public Key Infrastructure) è una collezione di tecnologie e processi per la gestione dei certificati l'associazione affidabile tra un'identità ed una chiave pubblica. La PKI facilita la cifratura, l'integrità dei dati, l'autenticazione dell'entità e la non repudiabilità.

Viene usata ad esempio in HTTPS per autenticare il server prima di una connessione cifrata

Cosa sono i certificati Self-Signed?

I certificati self-signed sono firmati dalla chiave privata corrispondente alla chiave pubblica stessa: ciò viene permesso grazie al fatto che nei browser è presente una lista di certificati fidati self-signed

Come fai a fidarti di Google nell'ambito dei certificati?

Posso fidarmi perché il certificato di Google è firmato da una CA. La CA è presente nel trust store del browser. Il browser considera quella Root CA affidabile. La fiducia è quindi delegata alla CA e basata su una catena di certificazione

Come posso evitare un attacco MITM grazie ai certificati?

Posso evitare un'attacco MITM associando alla chiave pubblica una firma così da risalire al proprietario (Viene aggiunta la firma della chiave pubblica, ottenuta applicando quella privata a quella pubblica). Ad esempio una carta di credito è autentica se ha a bordo chiave privata assieme al certificato digitale

(9) Malware

Cos'è un malware?

Malware = Malicious Software. È un software progettato per:

- Danneggiare un sistema
- Rubare informazioni
- Ottenere accesso non autorizzato
- Compromettere la sicurezza

Qual'è la differenza tra un virus ed un worm?

- Virus: Si attacca a un programma ospite. Richiede l'esecuzione da parte dell'host
- Worm: È autonomo. Si propaga via rete, non necessita di un programma ospite. I worm solitamente sfruttano le vulnerabilità del software es. Buffer Overflow mentre i virus tentano di abusare le funzionalità dei software

È generalmente più semplice scrivere un virus. Il worm è più efficace nella propagazione ed è più pericoloso perché si diffonde automaticamente

Quali sono le fasi di un virus?

- Infezione -> il virus si inserisce in un programma ospite
- Propagazione -> si diffonde ad altri file/sistemi
- Dormienza (eventuale) -> attende una condizione
- Attivazione (trigger) -> si attiva al verificarsi di un evento
- Payload -> esegue l'azione malevola

Cosa è il code-signing?

Il code-signing consiste nel verificare prima di eseguire/installare un software che esso arrivi da una fonte attendibile tramite verifica della firma, e che non sia stato modificato. Non posso tuttavia sapere se è firmato da un certificato rubato

Posso affermare che un sistema non è infetto?

No, affermare che un sistema non è infetto è matematicamente impossibile. Infatti non esiste un programma perfetto che rileva se un file è un malware. Posso solo utilizzare antivirus e protezioni per difendere il mio sistema il più possibile

Dove si possono nascondere i virus?

I virus possono nascondersi in quasi ogni tipo di file/programma. I file .txt sono una delle rare eccezioni perchè sono sicuri perchè contengono solo il testo. Tutti i file complessi come word pdf pptx etc invece contengono una parte di codice che spiega come visualizzare il file, oltre al testo, quindi possono essere infetti

Quali sono alcune tecniche utilizzate da virus per non essere rilevati?

I virus sono di diversi tipi e hanno sviluppato nel tempo varie tecniche per non essere rilevati:

- Corpo criptato: la prima parte è in chiaro, e decifra il payload che è cifrato
- Virus Polimorfi: il decryptor si automodifica dopo ogni duplicazione per evitare il riconoscimento
- Chiave Esterna: utilizzano una chiave esterna per criptare, ottenuta dalle componenti di sistema
- Virus Metamorfi: non hanno encryption ne decryptor, il virus riscrive il suo stesso codice, ad ogni infezione si trasformano

Qual'è la differenza tra virus polimorfi e metamorfi?

Polimorfo: Modifica la propria firma (es cifrando il payload), mantenendo una struttura simile

Metamorfo: Riscrive completamente il proprio codice. Cambia struttura interna, è più difficile da rilevare con signature-based detection

Cosa è un resident malware?

Un malware che rimane in memoria e continua ad operare anche dopo l'infezione iniziale, intercettando operazioni del sistema

Che tecniche usano gli antivirus per trovare e neutralizzare i virus? E per quelli particolarmente complessi?

Gli antivirus utilizzano molte tecniche per trovare i virus, la più usata è quella di testare programmi e file prima in un ambiente virtualizzato (macchina virtuale) così da verificare eventuali comportamenti anomali. Un'altra tecnica è quella delle signature: gli antivirus riconoscono i vari virus grazie a dei pattern comportamentali (es. un certo elenco di systemcalls) sono quindi in grado di rilevarli in modo simile a come avviene con l'analisi del DNA

Per i virus più complessi come quelli metamorfi non ci si può basare solo sulle signature (in quanto il virus cambia se stesso continuamente) ma si usano tecniche di analisi comportamentale (behaviour-based) per trovare pattern ricorrenti

Come fa un virus a non essere rilevato in una macchina virtuale?

- Controlla se si trova in un ambiente virtualizzato
- Verifica la presenza di strumenti di debugging
- Ritarda l'esecuzione
- Si attiva solo in condizioni specifiche
- Serve a evitare l'analisi dinamica

Se vengono eseguiti in un ambiente virtualizzato sono innoqui. Cercano segni del virtualizzatore (hyperv-v, QEMU), verifica del tempo di sleep, istruzione della CPU x86 di CPUID, leggono il bit Hypervisor, se è 1 si trovano in un ambiente virtualizzato. I virus ora offuscano il codice e reversarli è estremamente complicato.

Come sono chiamati gli antivirus moderni? Cosa fanno?

I moderni antivirus sono detto EDR (Endpoint Detection and Response), e sono dei sistemi che monitorano e reagiscono attivamente agli attacchi

Cosa sono i Trojan?

I trojan sono dei malware che si presentano come software legittimo e inducono l'utente a eseguirli volontariamente. Una volta eseguiti compiono azioni malevole.

Non si replicano autonomamente (a differenza dei worm). Spesso servono per installare backdoor, rubare dati e ottenere accesso remoto

Si camuffano per rimandare la detection. Molti trojan sono distribuiti all'interno di famosi programmi craccati o aggiornamenti finti

Cosa sono le Backdoors?

Le backdoors (letteralmente “porta sul retro”) sono dei modi per accedere ad un sistema bypassando i normali punti di accesso e controllo dell'accesso: sfruttano spesso i servizi di rete aprendo una porta dove l'attaccante può connettersi. Sono spesso create tramite trojan

Cosa sono i Rootkits?

I Rootkits sono softwares progettati per nascondere la presenza di malware, file processi o connessioni. Possono permettere di mantenere un'accesso privilegiato. Operano a livello user mode e Kernel mode. Si nascondono nel boot sector.

Una tecnica molto usata è il Syscall Hijacking, ovvero sostituire l'indirizzo di una systemcall con quella scelta dal rootkit. Solitamente vengono installati tramite drivers quindi bisogna fare attenzione quando vengono scaricati dalla rete

Cosa è un Auto-Router?

Un Auto-Router è un programma malevolo che scansiona un target per cercare una vulnerabilità e ottenere la shell root o installare un rootkit (solitamente con una backdoor)

Cosa sono i Ransomware?

Ransom = riscatto, sono dei virus pensati per ottenere un riscatto. I ransomware sono una conseguenza delle criptovalute come i bitcoin perchè permettono di rimanere anonimi: es. carica tot BTC su questo indirizzo. Utilizzano tecniche come i file lockers es. cifro tutti i file sul tuo pc e chiedo un pagamento per decriptarlo

Cosa sono le Botnets?

Le Botnets sono reti di computer compromessi (bot) controllati da un attaccante che li utilizza per DDoS, Spam, o attacchi coordinati. Sono controllati tramite server di comando e controllo (C&C)

Cosa è una logic bomb?

È una sequenza di istruzioni che si attiva se sono eseguite una serie di condizioni es. vendi un programma, se non vieni pagato blocchi il programma, oppure un impiegato licenziato quando si logga elimina il suo account

Cosa è il Social Engineering?

È una tecnica usata per ottenere accesso a dati o installare malware sfruttando la vulnerabilità fisica delle persone, es. mail che chiedono di resettare password o di accedere a conti bancari. Non è quindi un attacco HW o SW direttamente, ma avviene sul lato umano

(10) La Rete

Cosa è la rete? Cosa sono una LAN e una WAN? Cosa è un router?

La rete permette di fare scambiare dati da dei PC. Una rete locale è detta LAN (Local Area Network), mentre diverse LAN connesse tra loro formano una WAN. Un router è un dispositivo che raccoglie e smista il traffico, ha HW e SW dedicati. Serve solo per comunicare all'esterno della rete locale

Cosa è il Packet Switching?

È un metodo di comunicazione nel quale la comunicazione viene suddivisa in pacchetti più piccoli, e ogni pacchetto segue la strada più opportuna in quel momento. Una volta a destinazione il buffer del destinatario li riordina insieme. È un sistema a volte poco affidabile (posso perdere i pacchetti) ma è quello più efficiente e che sfrutta meglio la rete

Cosa è un MAC ADDRESS?

È un indirizzo in una LAN (di 48 bit/6 byte) che identifica univocamente un dispositivo e che teoricamente non è modificabile. È rappresentato da 6 coppie esadecimali, dove le prime 3 indicano la scheda di rete

Quali sono i protocolli connection-oriented?

- UDP (Protocollo Connection-less): è molto più veloce ed usato per connessioni realtime. Se un pacchetto viene perso si prova a ricostruirlo
- TCP (Protocollo Connection-oriented): controlla i pacchetti che mancano

UDP è più veloce ma senza garanzie di consegna o integrità (es. Streaming, giochi online), TCP è un protocollo affidabile che garantisce consegna e ordine dei dati

Come funziona il TCP? Come si stabilisce una connessione?

Il TCP funziona stabilendo una connessione tramite il Three Way Handshake:

1. SIN = 1, seq = x: il client chiede al server di aprire una connessione. Insieme al SIN è anche inviato un seq (numero iniziale casuale) per evitare

gli attacchi di TCP Hijacking

2. SIN + ACK, seq = y, ACK = x + 1: il server conferma di aver ricevuto il SIN del client, conferma di voler effettuare una connessione ed invia il suo numero
3. ACK, ack = y + 1: ora entrambi hanno il sequence number dell'altro, la connessione è stabilita

La comunicazione alla fine di interrompe con FIN o RST (reset)

Come viene scelto in che modo inviare un pacchetto?

Il dato viene creato a livello applicazione, e poi viene passato allo strato di trasporto che decide come spaccettarlo e se scegliere TCP o UDP

Cosa contengono i pacchetti?

I pacchetti IP hanno dimensione massima 2^{16} byte e hanno vari campi nell'header, tra cui indirizzo IP e porte del destinatario e mandante e poi il Payload. Un messaggio grande è spezzato in più pacchetti. Ogni pacchetto ha un Header, Payload e Footer (l'header identifica il protocollo usato dal pacchetto)

Cos'è una ARP Request?

Viene mandata una richiesta chiedendo se nella rete locale qualcuno abbia un determinato indirizzo IP. Se il router vede che l'host non è nella rete locale, invia a chi ha mandato la ARP request l'indirizzo IP del router che poi provvederà a mandarlo al reale destinatario su internet (o in un'altra rete)

Cos'è il Protocollo ICMP?

Il protocollo ICMP (Internet Control Message Protocol) è usato per controllo della rete e per pingare: si manda un pacchetto icmp a cui un server risponde, per sapere se esso è attivo o no. È un protocollo usato da IP per fare una serie di verifiche, e viene sfruttato per effettuare attacchi

(11) Web Security

Cos'è un DNS e come funziona? Come è formato un URL?

Un DNS (Domain Name System) trasforma degli indirizzi URL in indirizzi fisici. Un URL (Unified Resource Locator) identifica la posizione di files e pagine. È formato da un top level domain, un Global Top Level Domain (es. .com .org) e un Country Code (es. .it .uk)

Il browser manda una richiesta al DNS Locale, esso prova a risolvere l'indirizzo: se è nella rete locale, risponde, altrimenti chiede al provider che a sua volta chiederà al Root se non lo trova. Allora il browser contatterà il nodo richiedendo di risolvere l'indirizzo, e così via finché non si trova

Cos'è HTML?

È un linguaggio di markup per impaginare testo e può contenere codice (linguaggi di scripting) eseguito dal browser. Il codice JS nel documento HTML può essere remoto (caricato su un URL). Per inviare le richieste (es un form) può farlo tramite GET (in chiaro, nell'URL) o POST (dati nel body della richiesta, in modo nascosto)

Cos'è HTTP? Come funziona? Cos'è un HTTP Proxy?

L'HTTP (HyperText Transfer Protocol) è il protocollo principale di trasferimento dati tra web browser e server. Inizialmente il client del browser stabilisce una connessione TCP (HTTP Request) con il server (tcp scambia una serie di pacchetti con vari flag e campi ack). Il client può inviare una GET e una POST. Ogni hyperlink in una pagina HTML è una connessione TCP

HTTP Proxy è un server intermediato tra un client e un endpoint server, che fa da intermediario nell'accesso alle risorse del server e inoltra le risposte. Il proxy tiene traccia dei log delle richieste, ispeziona i contenuti e svolge le funzioni di firewall. Ha un sistema di caching per velocizzare la risposta e ridurre il traffico verso i server.

Cos'è un DOM?

Un DOM (Document Object Model) è un documento rappresentato da tutti i documenti che contiene gerarchicamente nella finestra che si sta visitando. Il DOM fornisce delle API (interfacce) a javascript per i contenuti della pagina, permettendo la modifica del contenuto e delle proprietà degli oggetti DOM

Cosa sono i Cookie? Che attributi hanno? A cosa servono?

Dato che HTTP è un protocollo stateless non si mantengono le informazioni tra varie richieste. Per questo si utilizzano i Cookie, dei piccoli file usati per memorizzare dei dati. Ogni volta che il browser visita un server, viene inviato il cookie di sessione per poter ripristinare quella eventualmente già esistente. I cookie possono essere persistenti o di sessione

Hanno vari attributi:

- Max-Age: Data di scadenza
- Domani: specifica in quali domini è valido

- **Http Only:** quel cookie può essere usato solo per connessioni http
- **Path:** indica a che pagina va inviato il cookie

I cookie vengono usati per la profilazione di un utente. Il sito web memorizza associato al cookie gli URL visitati e molte altre informazioni. I cookie vengono usati per mantenere l'ID della sessione per evitare di chiedere il login ogni volta, quindi c'è il rischio di furto di cookie: per questo devono essere protetti a livello server. Nel browser sono delle stringhe di caratteri cifrate.

Quali sono le vulnerabilità dei Cookie?

- Furto tramite XSS
- Intercettazione se non sono cifrati
- Session hijacking
- Mancanza di flag Secure o HttpOnly

Cos'è la SOP?

La SOP (Same Origin Policy) è una procedura di isolamento dei documenti: impedisce a una pagina di accedere ai dati di un'altra origine, definita da protocollo, dominio e porta. Serve a prevenire il furto di informazioni tra siti diversi ma non impedisce l'invio di richieste come nel CSRF.

Un origine è definita con la tripla (protocollo, dominio, porta) che la definisce. In questo modo ad esempio se sono su `https://bank.com` e provo ad accedere a `https://bank.com/account` posso farlo senza problemi, perchè hanno lo stesso protocollo dominio e porta. Se invece provassi ad accedere a `http://bank.com` (il protocollo è diverso), `https://api.bank.com` (il dominio è diverso) o `https://bank.com:8080` (la porta è diversa), questi siti non potrebbero leggere il DOM di `bank.com`, leggere i suoi cookie, inviare risposte HTTP o fare richieste.

Se la SOP è troppo rigida impedisce lo scambio di componenti nella pagina, l'esecuzione di script o la condivisione dello spazio di visualizzazione

Cosa è un CSRF? Cosa sfrutta? Come si combatte?

Un CSRF (Cross Site Request Forgery) è un attacco in cui si induce un utente autenticato a eseguire una richiesta non intenzionale. La richiesta viene inviata automaticamente dal browser

Sfrutta il fatto che il browser invia automaticamente i cookie e l'assenza di verifica dell'origine della richiesta. Non ruba cookie, ma sfrutta sessioni attive

Al giorno d'oggi è un attacco praticamente obsoleto in quanto l'attributo `SameSite` istruisce il browser su quando inviare dei cookie ad una terza parte

Cosa è XSS?

XSS (Cross Site Scripting) è un attacco in cui si inietta codice JavaScript malevolo in una pagina web. Il codice viene eseguito nel browser della vittima. Permette di:

- Rubare cookie
- Eseguire azioni a nome della vittima
- Modificare contenuto pagina

Come funziona Stored XSS? Come lo evito?

Nello Stored XSS gli script sono salvati nel filesystem del server, quando un altro utente visualizza la pagina con lo script contenuto, lo script malevolo verrà eseguito. È più pericoloso

es. Su un forum metto un commento che se caricato (senza fare nulla, 0 click) avvia un attacco per rubare i cookie

Per evitare ciò ci sono delle librerie che fanno la sanitizzazione degli input, oppure posso usare HTTP Only cookies: cookies che possono essere usati solo tramite HTTP e non javascript. Client-side invece posso usare un WAF (Application Level Firewall). Funziona solo con HTTP e non HTTPS perchè nel secondo caso i dati sono tutti criptati

Come funziona Reflected XSS? Come lo evito?

Il Reflective XSS si verifica quando un'applicazione (server) riceve dati in una richiesta HTTP e li include nella risposta immediata in modo non sicuro es. link in email phishing contengono URL appositamente formati, in modo che quando l'utente clicca al link la risposta includerà lo script dell'attaccante. È fatto da un server, una vittima e un sito web

Per evitarlo bisogna sempre verificare che tipo di link sto andando a cliccare, e se è scritto in maniera strana o punta a indirizzi sospetti

Cosa è un SQL Injection? Come si può svolgere?

Un SQL Injection è un attacco in cui l'attaccante inserisce codice SQL malevolo in un input dell'applicazione. Si verifica quando l'input utente viene concatenato direttamente nella query o non viene validato o sanitizzato. Permette di:

- Bypassare autenticazione
- Leggere dati dal database

- Modificare dati
- Eliminare tabelle

Si può svolgere inviando ad esempio:

' OR 1=1 –

Crea la situazione sempre vera: `SELECT * FROM users WHERE username = " OR 1=1 – AND password = "`;

Si cerca di aggirare la logica del controllo del DB per creare una condizione sempre vera e quindi accedere. Un esempio più avanzato potrebbe essere:

' UNION SELECT username, password FROM users

Estraggo delle credenziali

Quali sono le contromisure contro l'SQL Injection?

- Prepared statements (query parametrizzate)
- Validazione input (Sanitizzazione)
- Escaping corretto
- Principle of least privilege (DB user limitato)

Si cerca di dare poche libertà agli utenti del DB e soprattutto sanitizzare gli input. Al giorno d'oggi l'SQL Injection è facilmente evitabile con moltissime librerie di sanitizzazione degli input

(12) Network Security

Quali tipi di attacchi esistono?

- Attacchi passivi: difficili da rilevare e prevenire (non hanno un effetto visibile o constatabile sul sistema) es: intercettazione del traffico
- Attacchi attivi: compromettono la funzionalità del sistema es: Messaggi replay, Message Modification, DDOS. Non si possono prevenire, possono solo essere fermati quando stanno avvenendo

Cos'è lo Spoofing? E il packet sniffing? Come lo ostacolo?

Lo Spoofing consiste nel modificare l'indirizzo di origine di un pacchetto, per assumere l'identità di un server, un router, un host o un utente fidato e così facendo bypassare autenticazioni, intercettare il traffico o lanciare attacchi che sembrano provenire da fonti fidate. Lo spoofing non è necessariamente un attacco, ma è la base di molti attacchi. Si può fare Spoofing di moltissime cose come gli IP, l'origine di una mail, una posizione GPS ecc

Gli Attacchi Blind o IP Spoofing non vedono le risposte. Ovviamente fornendo un IP modificato come origine, se il pacchetto si aspetta una risposta la risposta andrà all'ip sorgente es. Utilizzo l'ip B per mandare una richiesta all'IP C, ma modifico la mia origine utilizzando l'IP spoofato A per fare credere a C di stare parlando con A. Tuttavia così facendo C invierà la risposta al vero A, e non a B

Per intercettare le comunicazioni fa il Packet Sniffing, ovvero leggere i pacchetti in una rete in modalità impossibile da rilevare (es. una LAN con un HUB invia i segnali in modalità broadcast). Il packet Sniffing è usato sia per difendersi che attaccare. In generale la fibra ottica è più sicura del rame. Wireshark è il più usato packet Sniffer

Nelle comunicazioni di tipo TCP/UDP il traffico è in chiaro, per proteggerlo devo utilizzare TLS. Per evitare lo spoofing posso utilizzare:

- Autenticazione forte
- HTTPS/TLS
- Verifica certificati
- Multi-factor authentication
- Controlli lato server

Cos'è un attacco DOS? Quali tipi ne esistono?

Un'attacco DOS (Denial Of Service) è un attacco che impedisce il funzionamento di un servizio rendendolo inutilizzabile sovraccaricandolo di richieste di vario tipo così da occuparlo completamente. Può riempire buffer RAM e CPU. Non è necessariamente un'attacco di rete, infatti saturando il file System di un firewall permetto a tutto il traffico di passare

Un attacco DOS distribuito è detto DDOS e si effettua con una botnet solitamente. Gli attacchi DOS e DDOS non sono prevedibili, possono solo essere fermati/arginati mentre stanno avvenendo (anche perchè non sono particolarmente pesanti)

Esistono diversi tipi di attacchi DDOS: - Ping of Death

- Smurf
- Land
- Syn Flood

In cosa consiste il Ping Of Death?

È un ping (ICMP echo request) che manda un pacchetto con lunghezza superiore a 65535 byte, facendo crashare la funzione di reassembly. Si tratta di una vulnerabilità del protocollo ICMP, sfruttando un errore di programmazione il

pacchetto ICMP va oltre il limite di dimensioni di 2^{16} byte appositamente, facendo un buffer overflow nel ricevente che andava a sovrascrivere codice di sistema

In cosa consiste lo Smurf Attack?

Attacco DoS basato su ICMP Echo Request (ping) ed IP spoofing

L'attaccante:

- Invia un ping all'indirizzo broadcast della vittima, indicando come source address un IP spoofato
- Il ping si propaga broadcast sulla rete: ogni host invierà una risposta
- La vittima si riempie la banda

Risultato: Amplificazione del traffico e sovraccarico della vittima

In cosa consiste un Land Attack?

Si fa Spoofing del mittente, e si invia un pacchetto con indirizzo della vittima sia come mittente sia come destinatario, così da andare in loop perchè il pacchetto di SYN = 1 e ACK = 1 vengono reinterpretate come nuove richieste esterne, permettendo di accettare un'altra connessione. Ogni pacchetto crea un entry nella tabella delle connessioni fino a saturarla. Ora non è più fattibile perchè se la porta ip src e dst sono uguali la connessione viene chiusa o sono scartati i pacchetti.

In cosa consiste un Syn Flooding?

È un attacco DoS. L'attaccante invia molte richieste SYN e il server risponde con SYN-ACK. L'attaccante non completa l'handshake. Il server mantiene connessioni half-open ed esaurisce le risorse. È un attacco di esaurimento risorse. È necessario che gli indirizzi spoofati non siano reali altrimenti risponderanno con RST=1 di fatto cancellando quella entry nella tabella della vittima.

Cosa è l'Ingress Filtering?

L'Ingress Filtering è un insieme di meccanismi di sicurezza di rete per prevenire lo spoofing degli indirizzi IP e gli attacchi DOS correlati. È utilizzato dai provider sui router per accettare solo pacchetti con indirizzi sorgente legittimi provenienti dalla rete del client

In cosa consiste il DNS Pharming?

È un attacco al Risolutore di indirizzi (DNS) che reindirizza a siti non affidabili. Il Pharming attack "avvelena" il mapping nome simbolico e ip address, si tratta

di anticipare la risposta di un server dns reale fingendosi un server dns. Questa vulnerabilità esiste perchè il DNS non usa la crittografia. Il GTLD (Global Top Level Domain) risponde con gli indirizzi dei NS (Name Server) che dovrebbero sapere come gestire una richiesta di traduzione. Si contattano più server finchè non arriva la risposta.

In pratica: se cerco di connettermi a siti legittimi il DNS mi indirizzerà a siti malevoli, perchè il suo mapping è stato modificato

Il DNS Spoofing consiste nel reindirizzare ad un indirizzo malevolo, mentre il DNS Pharming a inviare risposte DNS False

Cos'è e come funziona ARP?

L'ARP (Address Resolution Protocol) è il protocollo usato nelle LAN per scoprire a quale indirizzo MAC corrisponde un indirizzo IP (che serve per poter inviare pacchetti)

- Il Pc manda un messaggio broadcast chiedendo a chi da un determinato IP di rispondere con il suo MAC
- Il dispositivo corretto risponde mandando il suo MAC
- Nella sua cache viene salvata la corrispondenza IP -> MAC

In cosa consiste l'ARP Spoofing?

Durante un ARP Spoofing un attaccante manda delle false ARP Reply contenenti l'indirizzo IP della vittima e il proprio MAC address, il che porta a inserire nelle ARP Cache degli altri dispositivi delle entry false. ARP è stateless, si basa sulla fiducia, infatti un'azione così è nelle LAN

In cosa consiste l'ARP Poisoning?

È un "avvelenamento" della cache di un host, inserendo un dato falso. Dato che l'host è stateless ("non si ricorda le richieste che ha fatto"), quando riceve un ARP Reply si aggiorna/sovrascrive la tabella/cache, ed inviando delle ARP Reply finte (gratuitous ARP Reply) si cambia il MAC Address

In cosa consiste l'ARP Cache Poisoning?

ARP Cache Poisoning è una tecnica usata per realizzare un MITM in una LAN. L'attaccante invia ARP reply falsi: Dice al client "Io sono il gateway" e dice al gateway "Io sono il client": così il traffico passa attraverso l'attaccante.

Quale vulnerabilità sfrutta l'ARP poisoning?

Sfrutta il fatto che ARP non verifica l'autenticità delle risposte: è un protocollo privo di meccanismo crittografico o di autenticazione.

Cosa consente di fare l'ARP Poisoning? Che limiti ha?

L'ARP Poisoning permette di intercettare traffico, modificarlo, rubare credenziali, effettuare MITM, in alcuni casi causare DoS. Se il traffico è cifrato (es TLS): non può leggere il contenuto, ma può tentare downgrade o attacchi MITM più sofisticati

L'ARP Poisoning come limita ha il fatto di funzionare solo in LAN e non su Internet, non rompe la cifratura forte (es TLS corretto), può essere rilevato con strumenti di monitoraggio

In cosa consiste il MITM?

Un attacco MITM (Man In The Middle) consiste nell'interporsi tra due soggetti che credono di comunicare direttamente tra loro, per leggerne o modificarne le comunicazioni senza che essi se ne accorgano. Permette di effettuare sniffing e Dos. L'attaccante:

- Intercetta il traffico
- Può leggerlo (se non cifrato)
- Può modificarlo
- Può inoltrarlo senza che le vittime se ne accorgano

Può essere Passivo se intercetta solo i dati o Attivo se li modifica. Si può implementare tramite ARP Poisoning, DNS Pharming, TLS Hijacking.

Si può evitare tramite l'uso di TLS, VPN e verifica dei certificati

Come potrei interporvi tra un cliente ed una banca?

- MITM in LAN (o un ARP poisoning se il cliente è su rete non protetta)
- Certificato falso (CA compromessa) Se riesco a far accettare un certificato non valido
- Phishing inducendol'utente a collegarsi a un sito falso
- Downgrade attack forzando il protocollo meno sicuro

Se TLS è implementato correttamente:

- MITM puro non funziona
- Serve compromissione della fiducia (CA) o ingegneria sociale

In cosa consiste il TCP Hijacking?

Si tratta di dirottare una connessione TCP già stabilita. È un attacco ingneristico, non sfrutta bug. Il Seq number nel 3-way handshake parte da un numero casuale: sarà l'offset di partenza dei byte che invierà. Se i sequence number sono casuali è molto più difficile. TCP ritiene valido un pacchetto guardando solo i campi di porta e indirizzo IP, e ciò permette lo spoofing. Il comando rsh (remote shell) permette di eseguire comandi su altri pc tra host fidati, e gli host fidati sono contenuti nel file `/etc/hosts` o `/etc/hosts.equiv`. Modificandoli posso diventare un utente fidato. Si può evitare questo tipo di attacchi usando SSH, TLS o IPsec

Cosa è stato e come funzionava il Mitnick attack?

È stato un attacco storico basato su IP spoofing e TCP sequence prediction. L'attaccante:

- Spoofa l'IP di un host trusted
- Predice i sequence number
- Stabilisce una connessione TCP senza vedere le risposte

Si basa sulla vecchia debolezza nella generazione dei numeri di sequenza TCP

(13) Crittografia Online e Sicurezza

Quali sono i vari livelli di cifratura e in cosa consistono?

- Cifratura a livello di rete: il pacchetto o il payload IP è cifrato in tutto il percorso ed è decifrato dagli endpoint IPsec. Permette un buon livello di sicurezza a livello di rete e il programmatore non deve conoscere nulla di crittografia
- Cifratura a livello di trasporto: TLS che opera sopra il TCP cifrando i payload, mentre gli header TCP/UDP restano in chiaro. Si possono selezionare determinati IP e servizi da cifrare. In questo caso il programmatore deve usare librerie di crittografia e cryptosocket
- Cifratura a livello Applicazione: es. End-To-End, il traffico è cifrato e decifrato dalle applicazioni sender e receiver. TCP trasporta dati già cifrati a livello applicazione

TLS protegge i dati fino al server destinatario ma non protegge dal Server, mentre E2E i dati potranno essere decifrati soltanto dall'applicazione (es. Gmail può accedere alle tue mail volendo)

Cos'è e come funziona IPsec?

IPSEC (IP Security Suite) è un protocollo che offre servizi di sicurezza a livello di rete che sono automaticamente ereditati dai protocolli di trasporto e applicazione. Consente al protocollo IP di aggiungere della sicurezza aggiungendo 1 o 2 header ad IPv4. IPSEC È Il protocollo standard per le VPN: fornisce molti servizi flessibili di sicurezza offerti da 3 protocolli

Fornisce: Confidenzialità, integrità e authentication. questi 3 sono tutti opzionali e scegliibili.

Quali servizi offre IPSEC e come sono implementati?

IPSEC fornisce:

- Replay Protection: Il campo AH nel pacchetto IP fornisce un MAC per autenticare l'origine dei dati di un intero payload IPSEC e che i campi dell'header IP non siano modificati dal router. In questo modo fornisce protezione da Replay Attack (vengono inviati ad un destinatario dei messaggi intercettati che erano già stati mandati tra i due host)
- Tunneling: Il campo ESP (Encapsulating Security Payload) è una componente che permette la cifratura del payload IPSEC e fornisce autenticazione ed integrità. Ha due modalità:
 1. Tunnel mode: funzionalità di VPN. L'intero datagramma IP (escluso l'header) diventa il payload di IPSEC preceduto dall'header IPSEC, preceduto da un nuovo esterno header IPSEC. Ho l'incapsulamento dell'intero datagramma IP originale
 2. Transport mode: viene cifrato il payload IP, ma l'header IP originale resta visibile
- Key Management: Il campo IKE è un meccanismo per gestire e proteggere le chiavi, automatizzando lo scambio di chiavi utilizzando Diffie-Hellman

IPSEC decide se cifrare traffico in base alle policy configurate. Se il traffico soddisfa determinate regole viene applicata la SA e viene cifrato

Cosa sono SA e SAD?

Durante una connessione Ipsec una SA definisce: Parametri crittografici, Algoritmi, Chiavi, Durata. È un accordo tra due entità per proteggere il traffico

Il SAD (Security Association Database) è mantenuto in locale da ogni host ed è una tabella che contiene tutte le SA attive con i parametri crittografici associati

Senza SE IPSEC non sa come proteggere, senza la SAD non sa quale protezione usare per un pacchetto ricevuto

Cos'è HTTPS? Che cosa utilizza? Cosa permette questo servizio? Che algoritmi usa?

HTTPS (HTTP Secure) è una versione sicura di HTTP che utilizza TLS (Transport Layer Security) ed è il protocollo principale per il traffico sul web oggi. Un client inizia una connessione TLS e poi trasmette HTTPS attraverso il canale. TLS si monta sopra a TCP e fornisce servizi di sicurezza a livello applicazione. Il TLS incorpora:

- Crittografia asimmetrica -> per scambio chiavi
- Crittografia simmetrica -> per cifrare il traffico
- MAC -> per integrità

Il TLS permette:

- Autenticazione tra server e client
- Integrità, Data Origin Authentication (con MAC), confidenzialità (connessione criptata)
- Distrugge le chiavi di sessione a fine sessione
- Non fornisce non repudiabilità

TLS usa numerosi algoritmi per autenticazione (RSA, DH, DSA) per l'encryption (ChaCha20, AES) e per l'hashing (sha2, sha3). TLS incapsula i dati applicativi in record TCP e TCP trasporta questi record come payload

Come creo un canale TLS Client-Server? Come funziona l'Handshake?

La creazione di un canale TLS Client-Server coinvolge due protocolli:

- Handshake protocol: risolvere il problema del key exchange, client e server si mettono d'accordo sul protocollo da utilizzare, poi avviene lo scambio delle chiavi e vengono finalizzate le opzioni e i parametri del server
- Record protocol: viene cifrato il traffico utilizzando le chiavi create dall'handshake protocol

Come funziona l'handshake? L'obiettivo è ottenere una master key, un segreto di Client e Server che permetta di derivare tutte le altre chiavi

1. Il Client invia al Server un hello, inviando 1 byte che contiene gli algoritmi (CipherSuite) che ha a disposizione per la comunicazione

2. Il Server risponde con ServerHello, e gli conferma o suggerisce un'altro CipherSuite. Inoltre gli manda il suo certificato digitale
3. Il Client valida il certificato e genera una premaster secret con la chiave pubblica del server, inviandola al server
4. Si passa alla comunicazione cifrata

Ogni volta che mi connetto ad un sito web ho un handshake

Cos'è una Cipher Suite?

Una Cipher Suite definisce:

- L'algoritmo di cifratura
- L'algoritmo di hash/MAC
- Il metodo di scambio chiavi

È negoziata durante l'handshake

Quali sono le differenze tra IPSEC e TLS? Possono andare insieme?

Le principali differenze sono:

- TLS: Livello applicazione/trasporto, protegge singola applicazione (es browser). È più leggero per le applicazioni Web
- IPSec: Livello rete, protegge tutto il traffico IP. È più pesante a livello strutturale perchè protegge tutto

Possono andare insieme: IPSec può proteggere il traffico di rete, TLS può proteggere l'applicazione sopra

Cos'è una PSK?

Una PSK (Pre Shared Key) è una chiave che identifica una chiave master. È un segreto stabilito fuori dalla banda o una key da una precedente connessione TLS. Fondamentalmente è una chiave condivisa prima della comunicazione

Un etichetta PSK (PSK Label) indica una lista di algoritmi + l'hash usato dal KDF (Key Derivation Function) per derivare dal master key e le chiavi operative (es. chiavi di sessione). Il PSK usato da solo non garantisce la forward secrecy: se la chiave a lungo termine viene compromessa, anche le comunicazioni passate possono esserlo. La forward secrecy è invece ottenuta usando DHE o PSK + DHE, a condizione che le chiavi di lavoro siano effimere (cancellate dopo l'uso)

Come funziona la Server Authentication?

Se dopo il 3-Way Handshake TCP è abilitata l'autenticazione basata su certificati, durante l'handshake TLS il server invia un messaggio contenente il certificato e una firma digitale del transcript del protocollo TLS fino alla fine del ServerHello (se si usa autenticazione a certificati). Queste signature forniscono data origin authentication dei parametri di handshake firmati e dimostrano il possesso della chiave privata associata al certificato del server.

È obbligatorio lo scambio dei messaggi Finished sia da parte del client sia da parte del server al termine del TLS handshake (non della connessione). I messaggi Finished contengono un MAC calcolato su tutti i messaggi di handshake precedenti fino ai rispettivi punti, fornendo a ciascun endpoint:

- la prova dell'integrità dell'intero handshake
- la key confirmation, cioè la dimostrazione che l'altro endpoint conosce il segreto condiviso (master key / segreti derivati dal key schedule)

Cos'è e come funziona il Diffie-Hellman Key Exchange?

Il DH Key Exchange è un protocollo crittografico che consente a due entità di stabilire una chiave condivisa e segreta utilizzando un canale di comunicazione insicuro (pubblico)

Si considera un numero g , generatore del gruppo moltiplicativo degli interi modulo p (dove p è un numero primo)

1. Il Client sceglie un numero casuale a e calcola $A = g^a \bmod p$ e lo invia tramite canale pubblico al Server, assieme a g e p
2. Il Server sceglie un numero casuale b e calcola $B = g^b \bmod p$ e lo invia tramite canale pubblico al Client
3. Ora il client calcola $K_a = B^a \bmod p$ e il Server calcola $K_b = A^b \bmod p$. I due valori K_a e K_b sono identici.

Ora i due interlocutori hanno stabilito una chiave segreta e possono cominciare ad usarla per cifrare le comunicazioni, in quanto anche se qualcuno leggesse la comunicazione per calcolare a e b dovrebbe svolgere un'operazione di logaritmo discreto che è computazionalmente onerosa e sub-esponenziale, e quindi richiederebbe molto più tempo di calcolo di quello della attuale comunicazione

L'algoritmo di DH è attaccabile dal MITM attack, quindi per risolverlo si usano dei certificati

Cos'è la E2E Encryption? Quali protocolli utilizza?

End-to-End Encryption significa che solo i due endpoint possono leggere il contenuto, il server intermedio non può accedere al contenuto (es. Whatsapp). Telegram usa il protocollo MTProto, mentre Whatsapp e Signal utilizzano Signal

Come funziona MTProto?

MTProto è il sistema di comunicazione adottato da Telegram. La connessione tra due persone su Telegram è mediata da un server intermedio che stabilisce le chiavi tra di essi tramite Diffie-Hellman. Telegram offre due modalità di chat:

- Chat cloud: i messaggi sono decifrati e ricifrati sui server Telegram (il server quindi le può leggere)
- Chat segrete: utilizzano la crittografia E2E con chiavi generate con Diffie-Hellman, i messaggi non sono memorizzati sui server

MTProto utilizza SHA-256 per generare una chiave che cambia ogni 100 messaggi: di conseguenza se una chiave viene compromessa può esporre fino a 100 messaggi

Come funziona Signal?

Signal è il sistema di comunicazione adottato da Whatsapp e Signal. Utilizza un algoritmo Triple-DH per generare le chiavi. Le chiavi di Signal vengono cambiate dopo ogni messaggio, garantendo:

- Forward e Future Secrecy: impedisce di poter leggere o decifrare qualsiasi messaggio con una chiave compromessa, dato che cambia ad ogni scambio
- Message Unlinkability: non esiste una prova crittografica verificabile che colleghi un utente ad un messaggio specifico
- Offline Deniability: un utente può negare la sua partecipazione ad una conversazione
- Asincronia: permette agli utenti di iniziare una comunicazione con destinatari anche se non sono online

La E2E encryption di Signal è reale (non come Telegram) e i messaggi non restano sui server

Quali sono le differenze tra Signal e MTProto?

Aspetto	Signal	MTProto
E2E Encryption	Sempre attiva	Solo chat segrete
Cambio chiavi	Ad ogni messaggio	Ogni 100 messaggi
Forward Secrecy	Sì, completa	Limitata
Server access	No ai messaggi	Sì in chat cloud
Future Secrecy	Sì	No
Offline messaging	Sì	Limitato
Deniability	Sì	No

Come funziona l'autenticazione di una carta di credito?

La carta contiene: una chiave privata, un certificato pubblico, un microcontrollore. La chiave privata non esce mai dalla carta. Quando va autenticata:

- Il terminale invia una challenge alla carta
- La carta firma la challenge con la sua chiave privata
- Il terminale verifica con la chiave pubblica (dal certificato)

Se è valida la carta è autentica

Cos'è WEP? Perché oggi non è sicuro?

WEP (Wired Equivlent Privacy) è il primo protocollo di sicurezza Wi-Fi basato su RC4 e chiave condivisa. È vulnerabile perché usa IV corti e ripetuti che permettono di ricostruire la chiave osservando il traffico. Non è sicuro e oggi è sostituito da WPA2/WPA3

(14) Firewall

Cos'è un Cyber Security Framework? Quali sono i suoi punti?

Un Cyber Security Framework è uno standard di sicurezza adottato dalle organizzazioni su come costruire delle buone difese per il proprio sistema. I suoi punti solitamente sono:

- Identify: identificare gli asset da proteggere
- Protect: individuare il meccanismo di protezione più adeguato
- Detect: rilevare un eventuale tentativo di intrusione
- Respond: quando sto subendo un attacco, avere un piano e prevedere i possibili scenari e le relative risposte
- Recover: piano di recupero dopo aver subito l'attacco

Cos'è un Firewall? Come funziona?

Un firewall è un dispositivo o software che controlla e filtra il traffico di rete in base a regole predefinite. Permette di accettare, rifiutare e modificare i dati che passano tra due reti o tra una rete ed un dispositivo. Decide chi far passare e chi no in base alle regole impostate nella fase di configurazione, e tiene traccia

(logging) di tutto il traffico che passa. Si possono attivare notifiche in caso di pacchetti sospetti

Il firewall lavora a livello di rete e blocca i tentativi che arrivano dall'esterno. Il traffico in entrata è detto Inbound e quello in uscita Outbound. I firewall possono essere sia HW che SW. Non garantiscono la sicurezza totale, ma scartano le cose più banali. Servono a:

- Separare reti con livelli di fiducia diversi
- Impedire traffico non autorizzato
- Applicare una security policy

I pacchetti sono classificati in base a come le regole del firewall sono state configurate:

- ALLOW: permette al pacchetto di passare
- DROP: lo scarta
- REJECT: lo scarta e informa la sorgente (es. manda un TCP reset)

Quali sono le limitazioni dei Firewall?

I - Limitazione topologiche: il firewall assume che esiste un vero perimetro
- Malevoli insider: gli utenti all'interno del firewall sono considerati fidati, e potrebbero effettuare connessioni malevole
- Transito del firewall con tunnelling: le regole si basano sul numero di porta
- Contenuto cifrato: non si riesce a utilizzare il payload perchè cifrato, a meno che vengono fornite le chiavi di decrittazione con funzionalità simili ad un proxy

Quali tipi di Firewall esistono?

- Packet Filtering Firewall: lavorano sulle connessioni, oltre al contenuto del pacchetto vengono guardati anche quelli precedenti che formano una connessione (es: con TCP). Costruisce una tabella delle connessioni e riconosce quelli della stessa connessione
- Proxy Firewall: sdoppiano la connessione, ricevono i pacchetti, li analizzano e poi li mandano su un'altra connessione TCP permettendo di svincolare la rete interna da quella internet
- Personal Firewall: situato nei SO, filtra i pacchetti in entrata e uscita da un host

Cos'è il NAT? È una misura di sicurezza?

Il NAT in un firewall traduce gli indirizzi IP tra rete privata e Internet mantenendo una tabella delle connessioni. Permette a molti host interni di condividere un unico IP pubblico. Non è una vera misura di sicurezza ma solo un meccanismo di instradamento con effetto collaterale protettivo.

Cosa sono la Deny Rule e la Allow Rule?

Allow rule -> Passa tutto tranne quello che specifico

Deny Rule -> Non passa niente tranne quello che specifico

Come funzionano i Packet Filtering Firewall?

Contengono campi action e condizioni, funziona a condizione che il Firewall si basi sul contenuto del pacchetto che sta leggendo. Anche se sono il tipo di Firewall più vecchio vengono comunque usati per ragioni di velocità e come primo filtro per ridurre il traffico anomalo

Come funzionano i Packet Proxy Firewall?

Guardano l'header dei pacchetti IP. Hanno due proprietà: trasparenza all'utente e performance poco degradate

Circuit level Gateway è un proxy che non controlla il payload ma divide in due la connessione garantendo invisibilità della rete interna. Riesce a proteggere da attacchi come TCP SYN Flood (DOS), Ip spoofing, port scanning, ack flooding, blind detection, fragmented packet attacks, TCP session hijacking

Qual'è meglio tra Packet Filtering e Proxy? Perché?

I Firewall Proxy sono generalmente meglio: avendo un punto in cui il traffico si blocca si può controllarlo meglio, e analizzando più cose si possono loggare più cose. Lo svantaggio è dato dalla latenza rispetto al Packet Filter. Di default è impostata da deny rule (elenca i pacchetti che passano, tutto il resto è bloccato)

Cos'è un NGFW? Quali capacità ha?

Un NGFW (New Generation FireWall) sono i firewall di nuova generazione che introducono anche le protezioni da intrusion prevention e ispezione avanzata. Ha le seguenti proprietà:

- Application Awareness: Guarda la parte applicazione e la parte antivirus, ispezionando il traffico a livello applicazione per riconoscere e controllare specifiche applicazioni

- Native Integration (all-in-one): combina più funzioni in un unico dispositivo/software, firewall stateful, IPS (Intrusion Prevention System), controllo applicazioni, VPN, web filtering, anti-malware, report
- User Identity: permette policy basate su utenti o gruppi

Cos'è un personal Firewall? E un internet Firewall?

Personal Firewall: Firewall software implementato nei sistemi operativi

Internet Firewall: Firewall che fungono da gateway tra più subnetwork

Cos'è la DMZ?

La DMZ (Demilitarized Zone) è una sottorete tra la rete esterna (ostile) e quella interna da proteggere. I protocolli permessi in una DMZ dovrebbero essere minimizzati

Le aziende ci inseriscono i loro servizi pubblici, un utente internet accede solo alle macchine in DMZ, non c'è una connessione diretta tra la rete interna ed esterna: in questo modo un eventuale manomissione in DMZ non compromette la rete interna, dato che la DMZ ha un alto rischio di attacco. Gli utenti dell'intranet possono accedere sia a DMZ che ad internet, mentre da internet accedo solo alla DMZ. Solitamente contiene web server, DNS e informazioni per il funzionamento del web server

Cosa sono i Bastion Hosts?

I Bastion Hosts (macchine Hardenizzate) sono macchine che contengono delle versioni di software modificate, e sono più difficili da attaccare

Meno codice -> Meno falle -> Meno attacchi

Hardening: togliere componenti non essenziali a SW così da diminuire la superficie di attacco, es disabilitare tutte le interfacce, access points, apis

Dual-Homed host: è un computer con due interfacce una per l'interno e una per l'esterno. La funzionalità di routing tra le due interfacce è disabilitata

(15) IDS, SIEM e Privacy

Cos'è un IDS? E un IPS?

Un IDS (Intrusion Detection System) è un avanzato sistema di rilevazione minacce. Mentre gli antivirus non rilevano problemi come buffer o stack overflow, l'IDS estende l'idea dell'antivirus ad attacchi di ogni genere, ed utilizza anche strumenti come IA e Machine Learning per migliorare la fase di Intrusion Detection

IPS (Intrusion Protection System): sono degli IDS che sono in grado di reagire in realtime se un attacco è in corso (es. fermare un malware o resettare una connessione), gli IDS invece riportano semplicemente il problema

Quanti e quali tipi di IDS e metodi di rilevazione esistono?

- NIDS: Network Base IDS, basa le decisioni sul traffico di rete IP. Cercano di individuare gli attacchi con due strategie:
 1. Matching (Signature-Based): ispezionano la signature degli eventi come fanno gli antivirus per trovare pattern critici
 2. Behavioural-Based: ispezionano pattern e cercano effetti collaterali
- HIDS: Host IDS, basa le decisioni su dati di sys log di sistema ed altri apparati es. comandi shell, configurazioni di rete, dati dei processi
- Misused Detection: l'IDS apprende il comportamento naturale di un sistema, e se rileva un'esecuzione fuori dalla norma lo segnala al Security Analyst che deciderà se l'azione è lecita oppure no. Porta a molti falsi positivi, il massimo deve essere l'1% oltre è insostenibile per i security analysts
- Specification Based: Vengono definite delle specifiche tramite il quale l'IDS è in grado di rilevare comportamenti nuovi e identificarli se sono malevoli o consentiti

Cos'è un SIEM?

Un SIEM (Security Information Event Management) è un sistema che prendendo informazioni da moltissime fonti come firewall, antivirus, IDS o log, raccoglie dati fa correlazioni e cerca di capire cosa sta succedendo in un sistema. Hanno moltissime funzionalità, possono controllare accessi e i dati, informazioni su chi accede e setacciare il dark web in cerca di dati rubati. Le SIEM professionali arrivano a costare molto caro per le aziende essendo sistemi così complessi e completi

Cosa sono SOC e CSOC? Cosa sono i CERTS?

Le SIEM fanno prate di CSOC (Cyber Security Operation Center):

- SOC: Security Operation Center, centri centralizzati che convergono informazioni sulla sicurezza es. Telecom. SOC fa detection
- C-SOC: è il centro della sicurezza che controlla in tempo reale l'andamento della rete

Nei SOC operano i CERTS (Computer Emergency Response Team), gruppi di esperti che si occupano di gestire l'attacco e bloccarlo. I CERTS dei vari paesi

sono tutti collegati e svolgono attività di prevention. Ora sono chiamati CSIRT (Computer Security Incident Response Team)

I SOC sono strutturati su 3 livelli, di cui il primo è stato sostituito dai SIEM e dal machine learning. Il livello 1 è Monitoring, il 2 Deep Investigations, il 3 Advanced Investigation e Threat Hunting

Cos'è un Honeypot?

Un honeypot è un sistema volutamente vulnerabile che attira attaccanti e permette di studiare tecniche di attacco. È uno strumento di detection e ricerca, non serve a proteggere direttamente ma a monitorare

Perché la privacy ha valore? Cos'è la Digital-Privacy?

La privacy ha valore perché i tuoi dati personali potrebbero essere usati contro di te per effettuare profilazione o per venderti prodotti o in certi casi anche per ricatto o minaccia, e quindi vanno protetti. Le minacce alla privacy sono messe in pericolo da attacchi informatici, furto d'identità o data breach. Le persone non hanno un valore della percezione dei propri dati personali: io ti dò un servizio gratis significa che io uso i tuoi dati. Negli stati uniti la privacy non è un diritto, in Europa sì

Digital-Privacy: diritto degli individui di determinare quando e a che livello le informazioni che li riguardano possono essere comunicate ad altri.

Quali dati personali vengono venduti online? Cosa sono i dati PIL e Non-PIL?

I dati di tipo PIL (Personal Identifiable Information) sono dati che consentono di risalire direttamente ad una persona, mentre i Non-Pil no es. un film che hai visto

I dati venduti e rubati possono essere di qualsiasi tipo, dai dati personali (nome, nascita, telefono, dati bancari, dati biometrici) alle informazioni di profilazione (ricerche web, download, utilizzo di app, attività social) ai dati di posizione (dove ti trovi o dove vai) ai dispositivi della propria rete (dati della rete e dei tuoi dispositivi)

Perché il Privacy-Gap è un problema? Quali sono tipici attacchi che minacciano la Privacy?

Il Privacy-Gap è un problema perché le nostre informazioni online hanno molto valore, ma le persone non le percepiscono come tali e quindi non le proteggono adeguatamente. I dati viaggiano in chiaro sulla rete e possono essere letti da chiunque

I tipici attacchi sono ad esempio

- Furto D'Identità
- User Profiling
- Data breach

In cosa consiste il furto d'identità? E l'user profiling?

Il Furto D'Identità è l'acquisizione non autorizzata di informazioni personali, spesso per un guadagno economico. È eseguito spesso con attacchi phishing o data Breaches o social engineering o malware. Alla vittima può provocare perdite economiche, problemi legali, ed un impatto emotivo. I maggiori fattori di rischio sono i wifi pubblici, le transazioni online non sicure, password deboli e riutilizzo delle pw, mancanza di 2FA.

L'User Profiling è la profilazione del comportamento dell'utente dalle attività svolte per creare dei profili dettagliati degli utenti permettendo l'esperienza personalizzata e servizi mirati (come pubblicità mirata). La Sorgente della profilazione è tutta la attività online (siti visitati, click, ricerche, attività sui social media, posizione, cronologia acquisti). I Cookie WEB sono molto usati per la profilazione. Tecniche usate nella profilazione: cookie web, tracciamento dei pixel, machine learning, social network analysis, data breaches, fingerprint comportamentali

Cosa vuol dire Società della sorveglianza?

La Società della sorveglianza è una società in cui la raccolta massiva di dati permette il monitoraggio continuo degli individui. Collegata a Big data, Profilazione, Tracciamento online. Le PET servono a contrastare questa tendenza. È un sistema economico che trasforma l'esperienza umana in dati comportamentali da estrarre, analizzare e monetizzare.

Cos'è un Data Breach?

Un Data Breach è un accesso non autorizzato (spesso causato da hacking, malware, insider threat). Si tratta di una perdita di informazioni sensibili che portano ad un danno, abuso o sfruttamento

Cos'è il GDPR?

GDPR = General Data Protection Regulation. È una normativa europea che regola il trattamento dei dati personali, impone principi di minimizzazione, garantisce diritti agli utenti. Il suo obiettivo è proteggere la privacy e responsabilizzare le organizzazioni. Creano delle Direttive che tutti i paesi devono rispettare

Quali sono i punti fondamentali del GDPR?

Punti del GDPR:

- Diritto di accedere: ottenere la conferma del trattamento e accedere ai propri dati.
- Diritto ad essere dimenticati: Ottenere la cancellazione dei propri dati, quando ritiro il mio consenso o non sono più necessari
- Diritto alla portabilità dei dati: accedere ai miei dati in un formato leggibile come csv
- Diritto di rettifica: Correggere dati inesatti o completarli.
- Diritto ad essere informati
- Diritto di avere una copia dei dati che l'azienda ha
- Diritto di Opposizione: opporsi al trattamento per marketing diretto
- Diritto di essere notificati ogni volta che vengono aggiornati i diritti

Cosa includono i personal data? Cos'è il consenso informato?

I personal data includono dati come gli IP dei dispositivi e gli ID dei cookie, oltre alle informazioni mediche foto e allegati bancari

Il consenso informato è la richiesta di utilizzare i tuoi dati per poterti profilare. Spesso anche se viene rifiutato si viene comunque profilati

Cosa sono le PET? Cosa garantiscono?

Le PET (Privacy Enhancing Technology) sono tecnologie progettate per proteggere la privacy degli utenti minimizzando la raccolta e l'esposizione dei dati. Le PET garantiscono:

- Anonimato: poter operare sulla rete senza essere riconosciuto
- Pseudonimi uso di identità fittizia al posto di quella reale
- Inosservabilità: poter fare azioni senza che altri ne siano a conoscenza
- Non collegabilità: non è possibile collegare più azioni alla stessa persona

Un esempio di PET è TOR

Cosa permettono di fare le PET? I dati cifrati garantiscono la Privacy?

Le PET forniscono agli utenti dei modi di rinforzare le preferenze bloccando localmente cookie, ads e pop-up e remotamente usando dispositivi hardware fidati, HSM e TPM.

Anche se il contenuto è cifrato, si può fare traffic Analysis. Si analizza chi comunica con chi, frequenza, orari, volume traffico. Quindi non si legge il contenuto, ma si ricostruiscono relazioni sociali. Questo mostra che: la crittografia non garantisce anonimato

(BONUS) Criptovalute

BTC garantisce l'anonimato?

BTC garantisce uno pseudo-anonimato, infatti essendo pubblico il registro delle transazioni collegando più transazioni con un indirizzo è possibile ottenere delle informazioni.

Come implementa i soldi? Ha un'entità centrale?

BTC implementa i soldi con una funzione hash e una firma digitale. Non c'è un'entità fidata centrale

Cos'è la Block-Chain?

La Block-Chain è una struttura a Linked-List dove ogni blocco della lista rappresenta un insieme di transazioni e punta al predecessore tramite un hashlink. Un Hashlink è un campo che contiene l'hash del blocco precedente.

Perché la Block-Chain è così diffusa?

La blockchain è popolare perché permette di mantenere un registro condiviso, verificabile e immutabile tra soggetti che non si fidano tra loro, eliminando la necessità di un'autorità centrale e risolvendo il problema del double spending tramite meccanismi di consenso distribuito

Cosa sono i Nodes?

Il sistema si basa sui Nodi peer, che scambiano informazioni in un sistema distribuito.

- Full Nodes: effettuano la validazione delle transazioni e mantengono tutto lo storico (libro mastro) delle transazioni (circa 500gb).
- Light nodes: non contengono la storia di tutte le transazioni, ma solo delle ultime

Cos'è la POW? Cosa vuol dire minare un blocco?

La POW (Proof of Work) è un meccanismo in cui bisogna risolvere un problema computazionale per ottenere una ricompensa. Serve per dimostrare impegno computazionale

BTC è efficiente come sistema?

BTC è molto inefficiente sotto il punto di vista energetico e della produttività. Altre Blockchain utilizzano un meccanismo alternativo a PoW, chiamato PoS che è più efficiente

LABORATORIO

Cos'è un file ELF?

Executable and Linkable Format. Formato binario standard linux per eseguibili, librerie condivise e file oggetto. Contiene header, sezioni etc (la sezione .text contiene il codice macchina)

Cos'è uno shellcode?

È un pezzo di codice macchina utilizzato per fare un exploit (utilizzare una vulnerabilità per fare qualcosa di inatteso) in un programma vulnerabile (es. aprire una shell)

Cos'è un codice position independent?

È un codice che non dipende da un'indirizzo fisso di memoria. Usa RIP relative. Serve per ASLR, Shellcode

Qual'è la differenza tra shellcode ed eseguibile?

Shellcode: sequenza di istruzioni macchina, piccolo payload, non è un file strutturato, è inserito in memoria tramite exploit
Eseguibile: file strutturato (es. ELF), ha header, sezioni, metadati, è caricato dal loader

Qual'è la differenza tra formato oggetto ed eseguibile?

Formato oggetto: codice compilato ma non linkato, contiene simboli non risolti
Eseguibile: codice linkato, simboli risolti, pronto per essere eseguito

Cos'è e come funziona GDB?

GDB (GNU Debugger) è un programma che permette di eseguire un programma per tracciarne l'esecuzione, verificare il contenuto dei registri, inserire breakpoint e disassemblare funzioni

Che differenza c'è tra un linker statico e dinamico?

- Statico: unisce i file oggetto, crea il file ELF, inserisce PLT, GOT, etc (non conosce gli indirizzi reali delle funzioni esterne). Questo viene svolto quando compili gcc main.c
- Dinamico (dynamic linker): carica libc in memoria, risolve i simboli, scrive gli indirizzi veri nella GOT. È lui che “collega davvero” il programma alle librerie.

Cosa sono GOT e PLT?

Nel formato ELF:

- PLT (Procedure Linkage Table): Stub per chiamare funzioni dinamiche
- GOT (Global Offset Table): Contiene indirizzi reali delle funzioni

Usate per: Dynamic linking. Possono essere sfruttate in exploit (es GOT overwrite)

Da cosa è data la sicurezza di PKI?

PKI (Public key Infrastructure) non è decentralizzato. In PKI la fiducia è la certezza che una chiave pubblica appartiene realmente al suo possessore

Cos'è PGP?

PGP (Pretty Good Privacy) è un sistema crittografico per proteggere la comunicazione ed i file tramite cifratura, firma digitale e gestione delle chiavi. È un sistema decentralizzato basato su relazioni di fiducia tra gli utenti. La fiducia sta nel fatto che un'entità si fida che un'altra entità verifica e garantisce l'identità di altre persone.

Cosa sono Trust e Validity in PGP?

- Key trust: Quanta fiducia tu personalmente assegni alla capacità di un'altra persona di firmare chiavi. È impostata dall'utente per ogni chiave, si calcola, può essere full o marginal:

Full: c'è bisogno di una sola firma da un dominio fidato, oppure c'è bisogno di 3 firme valide marginal per diventare Full

Ultimate: solo tue per la tua chiave

Never: non ti fidi

- Key validity: È una misura di quanto sei certo che la chiave appartiene realmente all'identità dichiarata. È calcolato in base alla fiducia (Trust) (t) del proprietario e del numero di firme sulla chiave.

Full chiave valida per la comunicazione

Marginal: validità incerta, insufficiente

Unknown: non ci sono elementi per stabilire la validità

In pratica:

- Validity: La chiave è crittograficamente valida (firma corretta)
- Trust: Quanto mi fido della persona che ha firmato quella chiave

La validity è tecnica, la trust è soggettiva

Cos'è GPG? A cosa serve?

GPG è un PET. È utilizzato per cifrare un file in modo simmetrico. Quando uso gpg vengono generate due chiavi una per le firme e il controllo firme (SC, signature certification) e una per E (Encryption). Le chiavi possono essere scambiate tra diverse macchina esportandole ed importandole

Per firmare i dati uso `gpg -sign -u "NomeDellaChiave" --armor firma.txt` dove `firma.txt` è il file da firmare

Cos'è il Web Of Trust? Che differenza ha con la CA?

Il Web Of Trust è un modello usato da GPG. La fiducia è distribuita:

- Gli utenti firmano le chiavi degli altri
- Non c'è un'autorità centrale: è un modello decentralizzato

A differenza di CA (Certificate Authority) che è:

- Centralizzato
- Una Root CA firma i certificati
- Fiducia gerarchica

Cos'è un Rainbow Table Attack?

Una rainbow table è una tabella pre-calcolata di hash che permette di invertire rapidamente un hash cercando la password corrispondente. È un attacco time-memory trade-off, in cui si sacrifica spazio per ridurre il tempo di calcolo. Funziona bene se non è presente un salt, infatti l'uso del salt rende le rainbow table impraticabili perché richiederebbero una tabella diversa per ogni valore di salt

Cos'è John the ripper? A cosa serve?

John the Ripper è un software per craccare le password effettuando un bruteforce sull'hash. Si usa per vari tipi di cracks:

- Online Password Guessing: Tentativi diretti contro il server (limitabili con rate limiting)
- Offline Password Guessing: Si ottiene l'hash e si provano password offline
- Dictionary Attack: Si ha l'hash e si calcola l'hash di parole di un dizionario fino a trovare un match
- Bruteforce: tenta tutte le combinazioni possibili

Cos'è TOR? Da cosa è formato?

Tor è una PET che fornisce anonimato a livello di rete. Permette di nascondere IP dell'utente e rende difficile tracciare comunicazioni. Permette inoltre di accedere ai siti .onion del dark web

Un Relay è un server facente parte della rete TOR

Quali sono i protocolli di connessione usati da TOR?

- HTTP: chiunque vede il sito, locazione, dati (user / PW)
- HTTPS: chiunque può vedere il sito e l'IP dell'utente.
- TOR senza HTTPS: c'è una connessione cryptata tra il client e un relay o tra due relay adiacenti. Il primo relay conosce la posizione del client. Dopo l'ultimo relay i dati non sono più cifrati e chiunque può vederli
- TOR con HTTPS: Tra il client e un relay la connessione è cifrata. La posizione è sconosciuta anche al primo relay. I dati sono visibili solo dall'host finale e da possibile terze parte (lato del sito destinazione).

L'ultimo nodo può leggere il contenuto?

Se il traffico non è cifrato end-to-end, Sì, l'exit node può leggere il contenuto. Se invece c'è TLS sopra Tor, l'exit node vede solo traffico cifrato.

Come creo un circuito TOR?

1. Si sceglie un router onion (da una lista conosciuta) con ultimo nodo R_n
 2. Si sceglie una catena di $N - 1$ router. Il client sceglie i relay, così che conosce la loro chiave pubblica
 3. Manda un messaggio di creazione al primo router R_1
 4. Per ogni router consecutivo R_2 R_3 etc. estende il circuito
- Crea un messaggio specifico per R_m e cifra con la chiave pubblica di R_m
 - Manda un messaggio lungo il circuito esistente

Come funziona l'Onion Routing?

Per comunicare con il terzo relay si cifra 3 volte il messaggio $Ek_1(Ek_2(Ek_3(\text{messaggio})))$. Se il terzo nodo non usa https i dati saranno in chiaro (qualcuno potrà vederle senza conoscere il mittente)

Il messaggio è cifrato più volte. Ogni nodo rimuove uno strato di cifratura (come una cipolla, da qui “onion”). Questo garantisce separazione tra identità e destinazione

Come è fatta la struttura dei nodi?

Tor usa una rete di:

- Nodo di ingresso (Entry node)
- Nodo intermedio
- Nodo di uscita (Exit node)

Ogni nodo conosce solo:

- Il nodo precedente
- Il nodo successivo

Ma non conosce l'intero percorso

Come avviene una connessione TOR?

Un server non apre una connessione diretta con il client, ma usa anche lui una catena di relay (connessione).

Rendezvous-Point (RP): Nodo Tor scelto dal client

Introduction-Point (IP): Nodo/i Tor scelto dal server

1. Il server sceglie 3 Introduction Point (IP), costruisce 3 circuiti Tor. Il server crea documenti chiamati hidden service descriptors (descrittori del servizio), contenenti: chiave pubblica del servizio, quali sono gli IP attivi e altre info per la connessione. I descrittori vengono caricati su un insieme di nodi Tor che fungono da HSDir (Hidden Service Directories)
2. Il client che vuole accedere ad un sito onion, calcola quali HSDir contengono il descrittore, lo scarica e ottiene la lista degli IP
3. Il client sceglie un relay casuale come Rendezvous-Point, ci costruisce un circuito fino a questo nodo, e genera una chiave segreta (cookie)
4. Il client crea un circuito fino a uno degli IP, manda una richiesta di introduzione, indicando quale è RP e la chiave segreta
5. Il server riceve la richiesta dall'IP, non vede il client (vede solo un relay Tor e un RP da contattare)
6. Il server si collega al RP, costruisce un circuito e presenta la sua chiave segreta, RP collega i due circuiti

Da questo momento esiste un canale logico tra client e RP e Server e comunicano attraverso 2 circuiti (client-RP e server-RP)

Quali sono gli svantaggi di TOR?

- Più hops ci sono, più diventa lento il circuito
- Un nodo ha bisogno di molta larghezza di banda per servire molti utenti
- Una versione speciale di firefox è necessaria (TOR)
- Non è immune ad attacchi di deanonimizzazione

Cos'è Metasploitable? E Armitage?

È una macchina virtuale Ubuntu Linux intenzionalmente vulnerabile per esercitarsi in penetration testing

Armitage è come un'interfaccia utente intuitiva per Metasploit, che rende l'hacking più accessibile anche a chi non ha una profonda conoscenza della programmazione. In particolare visualizza i target, consiglia exploit ed espone le avanzate capacità del framework

Metasploit è un ottimo strumento, ma l'eccessivo affidamento ad esso può impedire l'apprendimento delle basi del pen testing.

Cos'è il Port Scanning?

Un port scan serve a verificare quali porte di un host sono aperte. Permette di identificare servizi attivi, capire quali applicazioni sono in ascolto, individuare possibili vulnerabilità

Cos'è Traceroute?

Traceroute traccia i router che il pacchetto attraversa, per farlo manda dei pacchetti ICMP con TTL inizialmente = 1 e manda n pacchetti incrementando il TTL (time to live) ad ogni pacchetto così che ogni router ricevendo il pacchetto con TTL = 1, lo decrementa e risponde. Il risultato è una stima del cammino, non una rappresentazione garantita del percorso reale dei pacchetti perchè potenzialmente ogni pacchetto potrebbe seguire una strada differente ma solitamente pacchetti simili seguono flussi simili.

Cos'è Nmap?

Nmap è un tool che fa port-scanning (per trovare le porte aperte) e può utilizzare molti protocolli (TCP,UDP,SCTP,IP,ICMP). Include molte euristiche per scovare le porte aperte, in base a come TCP/IP risponde ad alcune richieste di prova. Nmap interroga le porte TCP e UDP per determinare versione e i dettagli del SO.

Nmap può effettuare diversi tipi di scansione: TCP Connect scan, SYN scan (half-open scan), UDP scan, FIN scan, XMAS scan, NULL scan. Differiscono per completezza di handshake e livello di stealth

Come evito di essere rilevato mentre utilizzo Nmap?

Tecniche per ridurre rilevabilità: usare SYN scan (non completa handshake), rallentare scansione, fragmentation dei pacchetti, spoofing IP. Ma IDS avanzati possono comunque rilevare pattern anomali

Cos'è Iptables?

È un programma user-space per configurare il firewall

Cos'è SQLMAP?

SQLMAP è un tool python per SQL Injection (con pagina che risponde solo il numero di dati ottenuti si può effettuare ricerca binaria di nomi delle tabelle,colonne e tipo di una table)

Blind SQL Injection (Senza output): si può utilizzare uno sleep nella query, per determinare l'esito con successo o il fallimento della query. Con SQLMAP è possibile essere scoperti, visto che svolge molte richieste GET